Raccolta di esami

di

Sicurezza dei Sistemi Informatici

2011-2019

Capitolo 1
Introduzione alla sicurezza delle reti e dei sistemi informativi

1. **Parlare degli attacchi sniffing, spoofing e hijacking e descrivere le opportune misure di sicurezza.**

   Per sniffing s'intende il rilevamento dei pacchetti in transito in una rete e la loro analisi per carpirne informazioni sensibili; al fine di contrastarlo è necessaria cifratura dei pacchetti.

Lo spoofing è la falsificazione di un indirizzo IP al fine di accedere a risorse e sitemi; la contromisura è il non usare gli indirizzi per autenticazione.
L'hijacking (o Man In The Middle) è il dirottamento di una connessione da un parte di un individuo tramite la manipolazione o cancellazione di pacchetti; al fine di contrastarlo sono necessari riservatezza, autenticazione e integrità dei pacchetti

2. **Spiegare che cos'è il social engineering, fare un esempio di questo attacco, indicare le contromisure che un'azienda può adottare per difendersi.**
   Per social engeniiring si intende un tipo di attacco che non va a colpire il lato "informatico" di un'azienda/orgazizzione, ma quello umano, sfruttando le debolezze psicologiche e sociali delle persone poste in posizioni di rilievo. Un esempio molto rilevante e diffuso è il mail phishing che consiste nell'inivare email false che spingono l'utente a cliccare su link malevoli. La miglior contromisura che un'azienda può impiegare a riguardo è istruire i propri impiegati su questi rischi.

3. **Descrivere un attacco phishing e quali sono le misure per limitarlo.**
   Il mail phishing consiste nell'inviare email false che spingono l'utente a cliccare su link malevoli; alcune varianti sono il whaling (che attacca pezzi grossi) e lo spear phishing (che utilizza informazioni personali per aumentare le possibilità di successo). La miglior contromisura che un'azienda può impiegare a riguardo è istruire i propri impiegati su questi rischi.

4. **Spiegare che cosa è un attacco connection hijacking, come può essere condotto e quali contromisure si possono adottare.**
   L'hijacking (o Man In The Middle) è il dirottamento di una connessione tramite la manipolazione o cancellazione di pacchetti da un parte di un individuo che vi si immette, e può avvenire al livello fisico (tramite taglio del cavo) o logico (tramite ricezione dei pacchetti da un lato, manipolazione, e re-indirizzamento verso l'altro); al fine di contrastarlo sono necessari riservatezza, autenticazione e soprattutto integrità dei pacchetti

5. **Spiegare cosa si intende con malware food chain, chiarire perché ha questo nome ed illustrare con un esempio.**

6. **Spiegare che cosa sono gli attacchi di phishing e whaling.**
   Il mail phishing consiste nell'inviare email false che spingono l'utente a cliccare su link malevoli; il whaling è una variante che punta ad attaccare pezzi grossi di aziende o istituzioni. La miglior contromisura che un'azienda può impiegare a riguardo è istruire i propri impiegati su questi rischi.

7. **Che cosa significano le seguenti parole? Vulnerabilità, minaccia e security control? Come sono correlate?**
   Vulnerabilità: debolezza di un asset informatico

   Minaccia: evento intenzionale o accidentale che può causare la perdita di una proprietà di sicurezza sfruttando una vulnerabilità

   Security control: si usano per limitare/prevenire qualunque tipo di minaccia verso gli asset

8. **Che cosa significano le seguenti parole? Vulnerabilità, minaccia, asset ed attacco? Come sono correlate?**
   Vulnerabilità: debolezza di un asset informatico

   Minaccia: evento intenzionale o accidentale che può causare la perdita di una proprietà di sicurezza sfruttando una vulnerabilità

   Asset: l'insieme di beni, dati e persone necessarie all'erogazione di un servizio informatico

   Attacco: verificarsi di una minaccia di tipo "evento intenzionale"

9. **Spiegare cosa vuol dire DoS e fare esempi; perché è difficile da scoprire un attacco DoS; come difendersi da questi attacchi.**
   In un attacco DoS il funzionamento di un server viene impedito o limitato tramite vari metodi, come la distruzione fisica dei collegamenti o un flooding di richieste ai server al fine di sovraccaricarli; scoprire questo tipo di attacco è difficile perché spesso non è semplice identificare se si tratta effettivamente di un attacco o di un semplice malfunzionamento (senza contare il fatto che l'inaccessibilità del servizio rende difficile effettuarne una diagnostica); essendo un attacco prevalentemente di tipo brute force, non esiste un metodo semplice per proteggersi da esso se non aumentando la genera agilità e flessibilità del sistema in questione, magari aumentando il numero di server e collegamenti o migliorando l'efficienza dei software di sicurezza

10. **Cos'è Stuxnet? Come funziona e che lezioni possiamo concluderne?**
    Stuxnet è un malware che è una combinazione di worm + virus per sistemi Windows. Costituisce il prototipo di un nuovo tipo di attacco, perché è stato il primo caso noto di attacco verso i sistemi SCADA, che sono sistemi usati per controllare gli impianti industriali. Siccome i computer non erano collegati a Internet, il primo veicolo di infezione è stata probabilmente una chiavetta USB dei tecnici di manutenzione, e poi il malware si è propagato tramite i dischi di rete condivisi senza alcuna protezione.

11. **Dire cos'è la window of exposure e dove si può agire per ridurla**
    La finestra di esposizione è il periodo di tempo in cui il sistema è esposto a una minaccia di sicurezza:

    1. fase di scoperta: un attaccante sfrutta una vulnerabilità non nota:

    (a) un attaccante scopre una nuova vulnerabilità;

    (b) l'attaccante sviluppa un programma di attacco, chiamato exploit, che sfrutta tale vulnerabilità;

(c) l’attaccante inizia ad effettuare degli attacchi, facendo sì che la vulnerabilità diventi pubblica;

2. fase di pubblicazione: le persone cercano di limitare i danni:

(a) la vittima dell’attacco informa il produttore della vulnerabilità;

(b) il produttore informa tutti i suoi clienti dell’esistenza di tale problema;

(c) i clienti aggiornano gli strumenti di difesa (ad es. firme IDS), in attesa di una patch;

(d) il produttore rilascia una patch;

3. fase di protezione: i clienti applicano la contromisura:

(a) la patch è resa disponibile a tutti i clienti;

(b) solo quando tutti installano la patch, il problema può essere considerato risolto.

Per ridurla si possono fare controlli di sicurezza periodici per rilevare le vulnerabilità preventivamente , e notificare il pubblico il prima possibile in caso di attacco così da minimizzare i danni.

12. Bruce Scheiner ha scritto "security is a process, not a product" spiegare il significato di questa affermazione e fornire un esempio pratico di sua implementazione con elementi tecnici.

Comprare un singolo prodotto per fare sicurezza non è sufficiente per rendere un sistema protetto in quanto il singolo prodotto non è esente da bug, ma è necessario progettare il proprio sistema di sicurezza utilizzando più sistemi in parallelo, possibilmente di produttori diversi in modo da garantire una difesa maggiore.

L'esempio più pratico è utilizzare un firewall di un produttore e un sistema di identificazione di un secondo produttore (IDS), in questo modo in caso di bachi del primo prodotto, subentra il secondo per arginare i danni.

13. Definire i termini minaccia, vulnerabilità e security control, quindi spiegare quali relazioni intercorrono tra di loro e fornire un esempio per ciascun termine nel caso di una terna correlata

Vulnerabilità: debolezza di un asset informatico

Minaccia: evento intenzionale o accidentale che può causare la perdita di una proprietà di sicurezza sfruttando una vulnerabilità

Security control: si usano per limitare/prevenire qualunque tipo di minaccia verso gli asset

14. Spiegare brevemente la proprietà di sicurezza denominata integrità dicendo da quali attacchi protegge sia quando i dati a cui si riferisce sono memorizzati sia quando sono trasmessi.

(Risposta del professore)

Manipolazione dei dati. modifica e cancellazione.

Capitolo 2
Concetti base di sicurezza informatica

15. **Descrivere HMAC indicando i pregi e i difetti.**
HMAC è il più famoso e diffuso algoritmo per keyed-digest, ed applica una funzione di hash H, con blocco di byte B e output di L byte.

La sua forma è

HMAC=H(K' XOR opad || H(K' XOR ipad||data))

Dove:

-ipad: 0x36 ripetuto B volte

-opad: 0x5c ripetuto B volte

-K' calcolata nel seguente modo: presa una chiave K (|K|>=L)

if(|K|>B) then K'=H(K) else K'=K

if(|K'|<B) then K' 0-padded up to B bytes

Pregi e difetti:

+ pochi dati trasmessi date le piccole dimensioni del digest

+ prestazioni veloci

+ riservatezza e autenticazione con un singolo algoritmo di hash

- integrità parziale dato che possono avvenire collisioni

16. **Descrivere le proprietà di autenticazione e integrità di HMAC rispetto la firma elettronica.**
HMAC garantisce:

- integrità tramite digest
- autenticazione dei dati (ma non del mittente dato che chiunque può aver mandato quell' hash)

La firma digitale in più fornisce autenticazione del mittente perché l'hash viene cifrato usando la sua chiave privata, ed esiste un certificato X.509 che ne certifica l'identità

17. **What is integrity? Mention some possible attacks related to it?**
Si definisce integrità la proprietà che indica se un dato ha subito manipolazioni; alcuni possibili attacchi all'integrità di un messagio o pacchetto sono quelli di tipo MITM, i quali possono modificare i pacchetti nella connessione

18. **Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1kB con digest SHA-1 e chiave RSA 1024 bit.**
Supponendo cifratura AES-128-CTS (quindi no padding): si hanno:

-128B (1024 bit) chiave simmetrica AES cifrata con la Kpri del mittente

-128B (1024 bit) Kpub del mittente (in caso non si abbia HSM)

-1kb per il plaintext

-20B (160 bit) per il digest SHA-1

In totale 1300 senza HSM, 1172 con HSM (che mantiene la chiave nella propria memoria)

19. **Cosa significano i seguenti acronimi: DSA, RC-4, RIPEMD?**
-DSA: è un algoritmo di crittografia asimmetrica che fa esponenziale da un lato e logaritmo dall'altro; si usa solo per firma digitale (quindi niente cifratura), dato che la funzione che utilizza se applicata su plaintext causerebbe perdita dei dati

-RC-4: algoritmo di cifratura simmetrica di tipo stream, ovvero che si applica ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare

-RIPEMD: algoritmo di hash crittografico; considerato ottimo ma scarsamente utilizzato

20. **Dare una breve descrizione di: RC4, RSA, RIPEMD.**
-RSA: è un algoritmo di crittografia asimmetrica a blocchi che genera le sue chiavi usando due esponenti; la scelta di tali esponenti è fondamentale per la qualità del risultato finale (in particolare, il prodotto dei due esponenti deve essere inferiore alle dimensioni del blocco da cifrare)

-RC-4: algoritmo di cifratura simmetrica di tipo stream, ovvero che si applica ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare

-RIPEMD: algoritmo di hash crittografico; considerato ottimo ma scarsamente utilizzato

21. **RC-4 stream**
algoritmo di cifratura simmetrica di tipo stream, ovvero che si applica ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare

22. **Differenza algoritmi stream e a blocchi**
Gli algoritmi cifrano il file principale dividendolo in blocchi e cifrando ciascuno in maniera più o meno separata con la chiave in base all'algoritmo scelto (ad esempio ECB cifra ciascun blocco separatamente, mentre CBC cifra ciascuno blocco n dopo il primo facendone XOR con il risultato del passo n-1); gli algoritmi stream si applicano ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare (alcuni esempi sono RC4, Salsa20 e ChaCha20)

Gli algoritmi stream sono tendenzialmente più veloci di quelli a blocchi dato che effettuano un semplice XOR, ma richiedono costante sincronia tra mittente e destinatario (ciò non li rende buoni per le trasmissioni internet); di confronto, gli algoritmi a blocchi sono nettamente più lenti date le varie operazioni che è necessario effettuare per combaciare i dati alle dimensioni dei blocchi (come il padding), ma si ma si prestano molto bene alla trasmissione dei pacchetti internet

23. **Perché gli algoritmi di stream sono più veloci?**

Gli algoritmi stream sono tendenzialmente più veloci di quelli a blocchi dato che effettuano un semplice XOR, ma richiedono costante sincronia tra mittente e destinatario (ciò non li rende buoni per le trasmissioni internet), nonché il fatto che gli algoritmi a blocchi sono nettamente più lenti date le varie operazioni che è necessario effettuare per far combaciare i dati alle dimensioni dei blocchi (come il padding)

24. **Un'azienda deve scambiare con un'altra dei file ma possono utilizzare soltanto una chiave di 12 caratteri max; indicare come deve essere implementato il sistema (NOTA: volevano nella soluzione che si parlasse anche di kdf)**
Creo una chiave con K=pbkdf(pwd, sale, itc), e utilizzo IPsec in tunnel mode sui gateway aziendali per avere integrità dei dati e autenticazione del mittente; ipotizzando che i file da scambiare siano particolarmente sensibili, si consiglia l'uso della cyphersuite VPN-B per avere anche riservatezza sui dati

25. **Un messaggio di 28 byte viene cifrato con DES-CBC: quanti byte verranno inviati in totale?**
DES ha blocchi da 64bit (8 byte), quindi 28<32/8=4 blocchi da 8 byte più un blocco delle stesse dimensioni per l'IV, in totale (4+1)*8=40byte

26. **Se devo cifrare in modalità DES-CBC un file da 84 byte, quanti byte trasmetterò in rete?**
3DES ha blocchi da 64bit (8 byte), quindi 84<88/8=11 blocchi da 8 byte più un blocco delle stesse dimensioni per l'IV, in totale (11+1)*8=96 byte

27. **Avendo un file da 1500 byte, se lo cifro con 3DES-CBC quanto sarà grande il file finale?**
3DES ha blocchi da 64bit (8 byte), quindi 1500#8=4 byte nell'ultimo blocco che necessitano di 8-4=4 byte di padding per riempirlo, quindi in totale il file avrà dimensione 1500+4=1504byte

28. **CBC vs CTR: come funzionano, vantaggi e svantaggi**
CBC è un algoritmo di cifratura a blocchi che cifra ciascuno blocco n dopo il primo facendone XOR con il risultato del passo n-1 (per il primo passo si usa invece un vettore di inizializzazione IV, che in trasmissione può essere mandato nascosto o anche in chiaro)

    Vantaggi e svantaggi:

    + No attacchi di swapping

    + No attacchi known plain text

    - Propagazione degli errori in caso di perdita e errore in trasmissione di un blocco

    - No parallelizzazione CPU

CTR è un metodo per trasmettere file con dimensioni inferiori a quelle di un blocco: si dividono i dati in gruppi, e si mischia ciascun gruppo con un nonce+contatore che viene incrementato ad ogni gruppo (il nonce deve essere identico a destinazione)

Lo svantaggio principale è che la cancellazione di un blocco causa la desincronizzazione del contatore

29. **Due utenti desiderano scambiarsi via rete una serie di documenti informato ASCII (.TXT). Suggerire quali operazioni è opportuno svolgere su questi documenti prima di trasmetterli per resistere ad attacchi sulla rete (insicura). Si tenga presente che i documenti non contengono info riservate. Nota: non si usino protocolli o formati dati complessi. Si esprima la soluzione tramite formula (usando termini appropriati, come aes(k,d) piuttosto che enc(k,d))**
n=nonce+counter

k=DH

digest=hmac_sha256(k, P||n)

c=P||digest||n

30. **Utente A vuole mandare un messaggio segreto e autenticato agli utenti B e C, tutti e tre hanno un paio di chiavi RSA a testa. Descrivere il formato del data block per inviare il messaggio con le richieste proprietà di sicurezza.**
Bisogna cifrare con le chiavi pubbliche di B e C e firmare con la propria privata e distribuire la chiave pubblica di A, quindi:
-C riceve: AES_128(Kpub;c , M)||HMAC-SHA256(AES_128(Kpub;c , M), Kpri;a)||Kpub;a

-B riceve: AES_128(Kpub;b , M)||HMAC-SHA256(AES_128(Kpub;b , M), Kpri;a)||Kpub;a

31. **Parlare del meccanismo del keyed digest (cos'è, quando e come si usa, vantaggi e svantaggi).**
In un soluzione di questo tipo, si invia un digest calcolato non solo sui dati, ma anche su un segreto (chiave) e solo chi conosce K puo calcolare il digest sui dati ricevuti e confrontarli con il digest trasmesso. Tale soluzione e molto utilizzata in ambito di rete.

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il keyed-digest kd*R* calcolato sui dati ricevuti sarà diverso dal keyed-digest kd*F* ricevuto;

+ autenticazione: solo chi conosce la chiave segreta può aver generato un keyed-digest corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

− non ripudio: non è possibile stabilire quale peer ha generato i dati.

Vantaggi e svantaggi:

+ quantità di dati trasmessi: il keyed-digest è molto piccolo rispetto ai dati;

+ tempo di calcolo: gli algoritmi di hash sono veloci da eseguire;

+ implementazione: un singolo algoritmo di hash è sufficiente per garantire sia riservatezza sia autenticazione.

- integrità parziale: possono avvenire delle collisioni, poiché è teoricamente

impossibile individuare tutte le possibili modifiche

32. Parlare del keyed-digest e la firma digitale, quali sono le proprietà che offrono, vantaggi e svantaggi?

Keyed-digest: si invia un digest calcolato non solo sui dati, ma anche su un segreto (chiave) e solo chi conosce K puo calcolare il digest sui dati ricevuti e confrontarli con il digest trasmesso. Tale soluzione e molto utilizzata in ambito di rete.

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il keyed-digest kd*R* calcolato sui dati ricevuti sarà diverso dal keyed-digest kd*F* ricevuto;

+ autenticazione: solo chi conosce la chiave segreta può aver generato un keyed-digest corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

− non ripudio: non è possibile stabilire quale peer ha generato i dati.

Vantaggi e svantaggi:

+ quantità di dati trasmessi: il keyed-digest è molto piccolo rispetto ai dati;

+ tempo di calcolo: gli algoritmi di hash sono veloci da eseguire;

+ implementazione: un singolo algoritmo di hash è sufficiente per garantire sia riservatezza sia autenticazione.

- integrità parziale: possono avvenire delle collisioni, poiché è teoricamente impossibile individuare tutte le possibili modifiche

Firma digitale: viene calcolato un digest con un algoritmo crittografico e associato con un oggetto di dati in modo tale che qualsiasi destinatario dei dati può usare la firma per verificare l'origine e l'integrità dei dati

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il digest md*R* calcolato sui dati ricevuti sarà diverso dal digest md*F* ricevuto e decriptato;

+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

+ non ripudio: il mittente non può negare di aver firmato i dati, a patto che la sua chiave pubblica sia fornita da un certificato a chiave pubblica.

Vantaggi e svantaggi:

+ pochi dati aggiuntivi

- inapplicabile ad un flusso di dati in real time

33. **Un'azienda vuole fare firma digitale su tutti i suoi documenti e conservare sia i documenti sia le firme in modo da poterli verificare anche in futuro. Che cosa usare? Che cosa deve memorizzare insieme alla firma?**
Una enveloping CMS, contenente le varie firme associate a un dato documento e i corrispettivi certificati, più aggiornamento costante delle CRL associate alle varie firme possedute per verificarne la validità

34. **Quali proprietà di sicurezza offre la firma digitale, come si realizza, quali parti della firma offrono quelle proprietà di sicurezza.**
Nella firma digitale viene calcolato un digest con un algoritmo crittografico e associato con un oggetto di dati in modo tale che qualsiasi destinatario dei dati può usare la firma per verificare l'origine e l'integrità dei dati

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il digest md*R* calcolato sui dati ricevuti sarà diverso dal digest md*F* ricevuto e decriptato;

+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

+ non ripudio: il mittente non può negare di aver firmato i dati, a patto che la sua chiave pubblica sia fornita da un certificato a chiave pubblica.

Vantaggi e svantaggi:

+ pochi dati aggiuntivi

- inapplicabile ad un flusso di dati in real time

35. **Perché l'algoritmo SHA-1 è deprecato? Suggerire una possibile e valida alternativa e motivare perché questa sia migliore di SHA-1.**
SHA-1 era un algoritmo complessivamente buono, ma anche estremamente attaccato. Difatti, un gruppo di ricercatori cinesi e riuscito a trovare collisioni con soli 2^69

calcoli. È stato successivamente diffuso SHA-2. Come rimedio veloce dopo l'attacco a SHA-1, la famiglia SHA-2 e stata creata allungando il digest, in maniera simile a quanto avvenuto fra DES e 3DES.

36. Ordinare dal più veloce al più lento i seguenti algoritmi: SHA, AES_ECB, AES_CBC, RC4

SHA, RC4, AES_ECB, AES_CBC

37. Dati i seguenti algoritmi di cifratura, ordinarli dal più lento al più veloce: AES, DES, RC4, 3DES.

3DES, DES, AES, RC4

38. Descrivi la crittografia a curve ellittiche.

La crittografia a curve ellittiche (ECC) utilizza l'aritmetica delle curve ellittiche bidimensionali, invece dell'aritmetica modulare monodimensionale.

Dal punto di vista concettuale, invece di usare numeri (che sono punti su una retta) si prende lo spazio cartesiano, e i valori che sono validi sono solo i punti che soddisfano l'equazione di una curva ellittica.

Il problema del logaritmo discreto su una curva è più complesso da risolvere per i cattivi rispetto al problema del logaritmo discreto nell'aritmetica modulare, quindi le chiavi per l'ECC possono essere più corte (circa 1/10) per un livello di sicurezza comparabile, riducendo i requisiti di memorizzazione sui dispositivi embedded.

Alcuni esempi d'uso sono l'ECDSA (Elliptic Curve DSA) per firma digitale, e il ECDH (Elliptic Curve DH) per il key agreement.

39. Dire i due principali vantaggi degli algoritmi basati su ECC

Il problema del logaritmo discreto su una curva è più complesso da risolvere per i cattivi rispetto al problema del logaritmo discreto nell'aritmetica modulare, quindi:

1) Le chiavi per l'ECC possono essere più corte (circa 1/10) per un livello di sicurezza comparabile
2) Per i buoni tutti gli algoritmi richiedono solo due operazioni elementari che danno come risultato dei punti

40. Descrivi l'algoritmo di keyed-digest CBC-MAC.

Il MAC è costituito dall'ultimo blocco di testo cifrato risultante dall'applicazione di un algoritmo di crittografia simmetrica a blocchi in modalità CBC, con vettore di inizializzazione IV nullo (la riservatezza non è necessaria): tutti i blocchi di testo cifrato vengono buttati via eccetto l'ultimo, che viene preso come MAC) il destinatario potrà criptare i dati ricevuti con lo stesso algoritmo di crittografia e confrontare l'ultimo blocco di testo cifrato risultante con il blocco di testo cifrato ricevuto.

41. Uno dei primi metodi per criptare i dati?

Electronic Code Book (ECB), che consisteva in:

1. suddividere il testo in chiaro da criptare in blocchi base di dimensione fissa;

2. applicare l'algoritmo di criptazione su ciascun blocco *i*-esimo, indipendentemente dagli altri blocchi:

$$Ci = \text{enc}\ (K, Pi)$$

3. concatenare i blocchi risultanti per produrre il testo cifrato.

La decriptazione avviene invertendo la sequenza di operazioni:

$$Pi = \text{enc}{-}1\ (K, Ci)$$

Ormai obsoleto dato che era soggetto a vari tipi di attacco, tra cui principalmente swapping e known-plain text

42. Su sistemi embedded spesso si preferisce ECDSA rispetto a RSA: perché?

Perché le chiavi per l'ECC possono essere più corte (circa 1/10) per un livello di sicurezza comparabile, riducendo i requisiti di memorizzazione sui dispositivi embedded.

43. Qual è il principale vantaggio della modalità di cifratura CTR?

La capacità di parallelizzare la CPU nel calcolo, in quanto un qualsiasi gruppo può essere criptato senza dover criptare i gruppi precedenti (accesso casuale).

44. Indicare quale attacco all'integrità è possibile se dei dati D vengono protetti con un MAC calcolato nel seguente modo (k è la chiave e h è la funzione di hash): MAC =h (k || D).

Se si concatena un altro blocco in coda il digest sarà diverso e il buono non se ne accorgerà, quindi verrà cambiato il digest in qualche modo pur senza conoscere la chiave condivisa.

45. Vantaggi e svantaggi di cifratura fatta con enc(enc(p, k1), k2) con k1 e k2 chiavi diverse ma di lunghezza uguale

In genere non si utilizza mai un'applicazione doppia di algoritmi di cifratura, motivo per il quale viene evitata, dato che non aumenterebbe il livello di sicurezza in maniera significativa. Inoltre, l'applicazione doppia di algoritmi di cifratura e soggetta ad un attacco di tipo known-plaintext, chiamato meet-in-the-middle, che permette di decifrare i dati con al piu 2N+1 tentativi (per chiavi da N bit). In breve, raddoppia il tempo di calcolo ma la lunghezza della chiave aumenta di un solo bit.

46. Descrivere la tecnica crittografica ECB identificandone vantaggi e svantaggi.

L'Electronic Code Book (ECB), che consiste in:

1. suddividere il testo in chiaro da criptare in blocchi base di dimensione fissa;

2. applicare l'algoritmo di criptazione su ciascun blocco *i*-esimo, indipendentemente dagli altri blocchi:

$$Ci = \text{enc}\ (K, Pi)$$

3. concatenare i blocchi risultanti per produrre il testo cifrato.

La decriptazione avviene invertendo la sequenza di operazioni:

$$Pi = \text{enc}{-}1\ (K,Ci)$$

Vantaggi

• no propagazione degli errori: un errore nella trasmissione provoca un errore nella decriptazione di un solo blocco senza propagarsi agli altri blocchi;

• parallelizzazione della CPU: è possibile lavorare su più blocchi allo stesso tempo.

Svantaggi

• attacchi di swapping: la criptazione non dipende dalla posizione del blocco) è possibile scambiare due blocchi, o spostare un blocco, qualunque senza che ciò venga scoperto;

• attacchi known-plaintext: blocchi identici sono criptati allo stesso modo) un attaccante può costruire un database contenente gli output delle criptazioni con tutte le possibili chiavi di un blocco ricorrente (ad es. intestazione di un documento di Word), per poi trovare la chiave confrontando ogni blocco del testo cifrato alla ricerca del blocco ricorrente (pattern).

47. Quale delle seguenti tecniche – firma digitale, cifratura simmetrica, keyed-digest – sarebbe da preferire per proteggere l'integrità di un flusso di pacchetti a 1 Gbps? Giustificare la scelta.

Keyed-digest perchè è la tecnica più veloce, hash veloce e usa una sola operazione. La firma non si può fare su un flusso di dati. La cifratura è lenta

48. Quale tecnica è meglio usare per proteggere dati trasmessi in rete da attacchi di tipo replay? Cifratura simmetrica, cifratura asimmetrica, keyed-digest, altro? Giustificare.

Si parla di soli attacchi replay, quindi basta garantire Integrità con un keyed digest basato su chiave simmetrica (concordata a inizio sessione o meglio generata pseudo-randomicamente da un segreto condiviso):

d = kd(K||n||M||K)
invio M||n||d

Nel KD pongo K agli estremi in modo da evitare prefix e postfix attack

49. Due utenti devono scambiarsi dei file di testo formato ASCII (txt) non riservati. Come fanno a garantire che non vengano modificati durante il transito? Spiegare quali funzioni di sicurezza usare e enunciare la formula che produce il documento X trasmesso rispetto al documento originale. Si usino nomi significativi (es. aes(K,D) rispetto a enc(K,D).

k=DH, genero chiave
d=HMAC_SHA256(k, M), creo digest messaggio per integritàe autenticazione
X=M||d, invio messaggio + digest

50. **Si deve trasmettere cifrata una password da 12 caratteri con 2 byte di sale con AES. Cosa si usa tra ECB, CBC e CBF?**
CBF (ma non lo abbiamo studiato, ignorare)

51. **Dovendo cifrare con AES una password da 12 caratteri con 2 byte di sale è meglio usare ECB, CBC o CTR?**
Aes ha un blocco da 128 bit, 12 caratteri ascii quindi da 8 bit ciascuno sono 96 bit più 16 bit di sale sono 112 bit, quindi inferiore al blocco, il che mi porterebbe a usare CTR

52. **Firma digitale con digest SHA256, chiave privata RSA-2048 su un file da 10MB. Qual'è la dimensione della firma?**
Poiché viene utilizzato una chiave privata RSA-2048 la dimensione della firma sarà 2048bit

53. **Come possono inviarsi un file due tizi che condividono una password**
Tramite algoritmi a chiave simmetrica, usando la password come chiave

54. **Si deve firmare un documento da 10 MB con digest SHA-1 e chiave RSA. Quanto è grande esattamente la firma del documento?**
Dipende dalle dimensioni della chiave RSA. Ipotizzando che sia di 2048 bit, la firma sarà lunga anch'essa 2048 bit

55. **Quali algoritmi si possono usare per scambiare chiavi segrete?**
Quelli a chiave asimmetrica (come RSA), dato che non si deve inviare nessun segreto per farli funzionare

56. **Quali algoritmi si possono usare per comunicare una certa chiave segreta a una controparte?**
Quelli a chiave asimmetrica (come RSA), dato che non si deve inviare nessun segreto per farli funzionare

57. **Hash per calcolare la password partendo da un seme.**

58. **Per quale applicazione è stato inventato il CTS?**
La tecnica del ciphertext stealing (CTS) permette di usare gli algoritmi a blocchi in modalità ECB o CBC senza ricorrere al padding.

59. **Spiegare cos'è la modalità operativa CTS qual è l'idea principale su cui si basa la sua implementazione e perchè sta assumendo sempre più rilevanza**
Il CTS e una tecnica che permette di utilizzare algoritmi a blocchi senza il padding. All'ultimo blocco vengono aggiunti dei byte del blocco precedente, rimuovendoli dal penultimo blocco.Per evitare il padding standard, si utilizza come padding stesso una parte del ciphertext gia cifrato. Cio, per file di grandi dimensioni, non è drammatico, in quanto riguarda solamente gli ultimi due blocchi.. E' utile quando non si puo/vuole aumentare la dimensione dei dati dopo la cifratura.

60. **Perché non si usa 2DES e si preferisce 3DES?**

In genere non si utilizza mai un'applicazione doppia di algoritmi di cifratura come il 2DES, motivo per il quale viene evitata, dato che non aumenterebbe il livello di sicurezza in maniera significativa. Inoltre, l'applicazione doppia di algoritmi di cifratura e soggetta ad un attacco di tipo known-plaintext, chiamato meet-in-the-middle, che permette di decifrare i dati con al piu 2N+1 tentativi (per chiavi da N bit). In breve, raddoppia il tempo di calcolo ma la lunghezza della chiave aumenta di un solo bit. Il 3DES non ha invece di questi problemi.

61. **Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1 kB con digest SHA-1 e chiave RSA 1024 bit. 1Kb_file + 1Kb_PublicKey + 160bit_storedDigest = 2208 bit: per decifrare il file abbiamo bisogno di esso e della chiave pubblica. Per autenticarlo servono il digest e la chiave pubblica per verificarlo**

62. **Quali algoritmi base (non strutture dati complesse) si possono utilizzare per garantire riservatezza di un file situato su un server di cui non ci si fida?**

63. **Spiegare il termine security through obscurity. Spiegare perché alcuni dicono sia buono ed altri no.**
Tentare di mantenere o aumentare la sicurezza di un sistema tenendo segrete la progettazione o la costruzione di un meccanismo di sicurezza. Alcuni non lo ritengono un buon metodo di difesa perché in un sistema open è più facile trovare ed annunciare eventuali vulnerabilità.

64. **Spiegare la authenticated encryption.**
Gli algoritmi authenticated encryption (AE) combinano le operazioni di crittografia e

keyed-digest in una singola operazione:

+ riservatezza e autenticazione (e integrità) con un solo algoritmo e una sola chiave;

+ maggiore velocità;

+ minor rischio di errori di implementazione.

L'AE sta diventando una necessità sempre più crescente a livello applicativo (ad es. per i messaggi di posta elettronica).

Gli algoritmi AE possono essere:

• AEAD o no: alcuni dati autenticati possono essere lasciati non criptati;

• single-pass o double-pass: un algoritmo double-pass ha bisogno di memorizzare i risultati della prima passata per ulteriori calcoli) è almeno due volte più lento di un algoritmo one-pass se implementato in software;

• on-line o off-line: i dati possono essere presi così come arrivano dal filo o devono essere prima salvati tutti.

I normali schemi di criptazione sono soggetti ad attacchi chosen-ciphertext (oracle) se usati on-line:

1. l'attaccante modifica un testo cifrato;

2. l'attaccante osserva se il ricevente segnala errore o meno.

65. CBC e CTR mode: spiegare, vantaggi e svantaggi.

CBC è un algoritmo di cifratura a blocchi che cifra ciascuno blocco n dopo il primo facendone XOR con il risultato del passo n-1 (per il primo passo si usa invece un vettore di inizializzazione IV, che in trasmissione può essere mandato nascosto o anche in chiaro)

Vantaggi e svantaggi:

+ No attacchi di swapping

+ No attacchi known plain text

- Propagazione degli errori in caso di perdita e errore in trasmissione di un blocco

- No parallelizzazione CPU

CTR è un metodo per trasmettere file con dimensioni inferiori a quelle di un blocco: si dividono i dati in gruppi, e si mischia ciascun gruppo con un nonce+contatore che viene incrementato ad ogni gruppo (il nonce deve essere identico a destinazione)

Lo svantaggio principale è che la cancellazione di un blocco causa la desincronizzazione del contatore.

66. Qualcuno ti ha inviato un file firmato digitalmente con RSA e SHA-. . . , insieme al certificato del firmatario e al certificato della sua CA. Descrivere come validare la firma, identificare le informazioni richieste ed ottenere l'accesso ad esse.

67. Descrivere DH, i suoi problemi e le soluzioni ad essi.

Diffie-Hellman (DH) è stato il primo algoritmo ad usare il concetto di pubblicare qualche cosa (i numeri p e g), e quindi in questo senso spesso è definito come il primo algoritmo a chiave pubblica inventato.

DH non è un metodo per distribuire la chiave, ma per concordare la chiave:

1. il mittente X e il ricevente X scelgono o concordano due numeri interi pubblici, un generatore g (tipicamente 2, 3 o 5) e un numero primo p (grande), tali che $p > g > 1$

2. X sceglie arbitrariamente un numero intero $x > 0$ (grande), e calcola $A = gx \bmod p$

3. Y sceglie arbitrariamente un numero intero $y > 0$ (grande), e calcola $B = gy \bmod p$

4. X invia (pubblica) il valore calcolato A a Y ;

5. Y invia (pubblica) il valore calcolato B a X;

6. X riceve B, e calcola $KA = Bx \bmod p$

7. Y riceve A, e calcola $KB = Ay \bmod p$

8. per la proprietà delle potenze, i valori KA e KB, calcolati indipendentemente da X e Y , sono uguali e costituiscono la chiave segreta KAB:

$$KA = (gy)x \bmod p,$$

$$KB = (gx)y \bmod p$$

$$\rightarrow KA = KB = gxy \bmod p = KAB$$

Il problema principale di questo algoritmo sta nella fase di key agreement: nel caso in cui però l'attaccante sia in grado di manipolare i dati in transito, può allora sniffare il traffico tra le parti manipolarli. Questa operazione risulta del tutto trasparente al mittente e al ricevente: essi non hanno modo di sapere che al di là del canale protetto non c'è la controparte ma c'è l'attaccante, le chiavi che credono di aver concordato sono diverse, e i dati sono stati manipolati. È quindi necessario proteggere le chiavi scambiate tramite un processo di pre-autenticazione usando:

• certificati per le chiavi DH;

• protocolli autenticati varianti del DH

68. RSA, RC4, SHA-1, . . . : qual è l'intruso e perché?
sha1 perché è un algoritmo di digest mentre gli altri di cifratura

69. Descrivere step-up (gated) cryptography.

70. Spiegare brevemente la tipologia di cifratura simmetrica e quella asimmetrica, indicando i vantaggi e svantaggi di ciascuna tipologia.

(Risposta del professore)

1) simmetrica: C = enc (K,P), P = dec (K,C);
vantaggi: veloce, key generation semplice
svantaggi: key distribution

2) asimmetrica:
svantaggi: lenta, key generation, key distribution

Capitolo 3
Sistemi di autenticazione

71. Sistemi di autenticazione a sfida simmetrici, vantaggi e svantaggi.

Un sistema a sfida è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida; la versione simmetrica richiede che la risposta alla sfida sia calcolata con la chiave comune condivisa col server

Pro e contro:
+ no sniffing
+ no replay (la sfida contiene un nonce)
- lato client, l'utente deve avere un funzione di hash per calcolare la risposta (non sempre possibile)
- il server non può memorizzare l'hash delle password, ma deve conoscerle in chiaro al fine di calcolare l'hash della soluzione
- la sfida passa in chiaro

72. Autenticazione simmetrica, cos'è, come funziona, vantaggi, punti deboli.

Un sistema a sfida è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida; la versione simmetrica richiede che la risposta alla sfida sia calcolata con la chiave comune condivisa col server.

Procedura di autenticazione

1. identificazione: il client invia il proprio UID;

2. richiesta di una prova: il server genera un numero nonce e casuale n e lo invia come **sfida**;

3. prova: il client calcola il keyed-digest sulla sfida ricevuta, usando il segreto condiviso k come chiave

$$d = H(k, n)$$

e trasmette il keyed-digest d calcolato come soluzione alla sfida;

4. controllo: il server esegue lo stesso calcolo della soluzione usando la sfida generata e il segreto condiviso, e confronta la prova d ricevuta con la soluzione calcolata:

$$\text{if } (d = H(k, n)) \text{ then OK else ALARM}$$

Pro e contro:
+ no sniffing
+ no replay (la sfida contiene un nonce)
- lato client, l'utente deve avere un funzione di hash per calcolare la risposta (non sempre possibile)
- il server non può memorizzare l'hash delle password, ma deve conoscerle in chiaro al fine di calcolare l'hash della soluzione

- la sfida passa in chiaro

73. Kerberos è detto essere un sistema di autenticazione TTP. Spiegare perché è classificato in questo modo e quale rischi corrono i client ed i server applicativi se il terzo non si comporta correttamente.

TTP sta per Third Thrusted Party, e kerberos ha questa definizione perché il suo sistema di autorizzazione utilizza anche un server di rilascio di ticket intermedio tra pretender e verifier.

74. Kerberos: spiegare cosa significa trusted third party.

TTP sta per Third Thrusted Party, e kerberos ha questa definizione perché il suo sistema di autorizzazione utilizza anche un server di rilascio di ticket intermedio tra pretender e verifier.

75. Spiegare cos'è l'attacco dizionario: sotto quali ipotesi può essere condotto e quali contromisure adottare.

Un attacco a dizionario è un tipo di attacco a forza bruta con lo scopo di scoprire una password conoscendone l'hash (= digest): viene usata una lista, detta dizionario, che contiene solo le password più probabili, ovvero quelle che gli esseri umani scelgono più di frequente perché facili da ricordare.

Può essere condotto se l'attaccante ha accesso alle informazioni nel server:

- ha il database del server contenente gli hash corrispondenti alle password degli utenti

- conosce l'algoritmo di hash usato per calcolare gli hash

Utilizzando del "sale" (ovvero una stringa randomica aggiunta alle è password prima dell'hashing) si annulla completamente il rischio di questo attacco

76. Confrontare le tematiche di autenticazione a sfida simmetrica ed asimmetrica identificando chiaramente vantaggi e svantaggi di ciascuna di esse.

Un sistema a sfida è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida.

Si dividono in due tipologie:

• simmetrici: l'utente conosce un segreto condiviso: dimostra di conoscere il segreto senza trasmetterlo, ma usandolo per effettuare un calcolo.

Pro e contro:

+ no sniffing

+ no replay (la sfida contiene un nonce)

- lato client, l'utente deve avere un funzione di hash per calcolare la risposta (non sempre possibile)

- il server non può memorizzare l'hash delle password, ma deve conoscerle in chiaro al fine di calcolare l'hash della soluzione

- la sfida passa in chiaro

• asimmetrici: l'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

77. Cos'è una rainbow table?

Le rainbow table sono degli speciali database precalcolati che permettono di raggiungere un compromesso tra:

• memoria: solo un sottoinsieme degli hash è salvato nel database precalcolato

• tempo di calcolo: quando la catena viene trovata, occorre ripercorrere la catena per trovare la password

78. Spiegare il metodo della sfida asimmetrica elencando punti di forza e deboli del metodo e dei singoli componenti che partecipano.

Un sistema a sfida asimmetrica è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida. L'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Procedura di autenticazione

1. identificazione: il client invia il proprio certificato a chiave pubblica;

2. richiesta di una prova: il server genera un numero n nonce, lo cripta usando la chiave pubblica Kpub presa dal certificato

$$s=enc(Kpub, n)$$

e invia il numero criptato come sfida s;

3. prova: il client decripta la sfida s ricevuta usando la propria chiave privata Kpri e trasmette il numero in chiaro come soluzione alla sfida;

prova=dec(Kpri, s)

4. controllo: il server confronta la prova ricevuta con il numero generato *n*:

if(prova = n) then OK else ALARM

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

79. Autenticazione a sfida asimmetrica

Un sistema a sfida asimmetrica è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida. L'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Procedura di autenticazione

1. identificazione: il client invia il proprio certificato a chiave pubblica;

2. richiesta di una prova: il server genera un numero n nonce, lo cripta usando la chiave pubblica Kpub presa dal certificato

s=enc(Kpub, n)

e invia il numero criptato come sfida s;

3. prova: il client decripta la sfida s ricevuta usando la propria chiave privata Kpri e trasmette il numero in chiaro come soluzione alla sfida;

prova=dec(Kpri, s)

4. controllo: il server confronta la prova ricevuta con il numero generato *n*:

if(prova = n) then OK else ALARM

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

80. Spiegare cos'è un sistema di autenticazione a sfida asimmetrica, indicando quali messaggi vengono scambiati tra il client e il server che autentica e quali vantaggi e svantaggi presenta.

Un sistema a sfida asimmetrica è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida. L'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Procedura di autenticazione

1. identificazione: il client invia il proprio certificato a chiave pubblica;

2. richiesta di una prova: il server genera un numero n nonce, lo cripta usando la chiave pubblica Kpub presa dal certificato

s=enc(Kpub, n)

e invia il numero criptato come sfida s;

3. prova: il client decripta la sfida s ricevuta usando la propria chiave privata Kpri e trasmette il numero in chiaro come soluzione alla sfida;

prova=dec(Kpri, s)

4. controllo: il server confronta la prova ricevuta con il numero generato *n*:

if(prova = n) then OK else ALARM

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

81. Spiegare che cosa è un sistema OTP time-based, indicando quali informazioni vengono trasmesse dal client al server di autenticazione e quale funzionalità è associata a ciascuna informazione trasmessa.

Nelle time-based OTP la password dipende dal tempo e dal segreto dell'utente: p(ID; t) = h(t; SID). E' richiesto inoltre un calcolo locale al claimant e la sincronizzazione dei clock. La password e ottenuta mediante un hash di tempo e segreto dell'utente.

82. Spiegare brevemente il concetto di OTP e quale problema di sicurezza risolve. Spiegare, quindi, con l'ausilio di appropriate formule, le fasi di inizializzazione e verifica nel protocollo S/KEY.

(Risposta dal professore)

Risolvono sniffing, MITM, replay.
S/KEY: inizializzazione sul server con l'ultima password PN = hN(s), verifica h(PN-1) = PN

83. Spiegare come funziona il timestamp (sicuro).

Capitolo 4
Lo standard X.509, le PKI ed i documenti elettronici

84. Che cos'è PKCS#10?

PKCS #10 è il formato standard usato da un utente per la richiesta di un certificato alla CA.
La richiesta PKCS #10 contiene:

• il distinguished name (DN) dell'utente richiedente;

• la chiave pubblica da certificare;

• eventuali attributi, tra cui:

– una password a sfida tramite la quale l'utente potrà in seguito richiedere la revoca del certificato;

– gli attributi (ad es. PKCS #9) che dovranno essere inseriti nel certificato;

– altre informazioni sul richiedente.

La richiesta PKCS #10 viene firmata con la chiave privata corrispondente alla chiave pubblica da certificare) la CA può verificare che il richiedente sia il legittimo titolare della chiave pubblica.

85. Che cosa è e per quale scopo è usato PKCS#11?

PKCS #11 è una API di sicurezza di basso livello che offre agli sviluppatori delle applicazioni un'interfaccia standard per accedere alle primitive del PSE di livello inferiore.
Fornisce un motore crittografico in grado di svolgere le operazioni di crittografia base (ad es. firma, criptazione), che è implementabile:

• in software: una libreria che implementa tutti gli algoritmi;

• in hardware: una libreria che è uno stub verso un PSE hardware

86. Dove si trova una CRL distribution point e cosa significa?

CRL distribution point (aka CRLDP o CDP) è un'estensione pubblica di un certificato X.509: identifica il punto di distribuzione della CRL da usare nella verifica della validita di un certificato. Puo essere una directory entry, e-mail o URL.
Può essere critica o non critica.

87. Dato un certificato X.509 spiegare quali sono le sue proprietà di sicurezza intrinseche e come sono ottenute.

Autenticazione e integrità tramite la firma della CA e la lista degli algoritmi usati per firmare.

88. Cos'è un certificato X.509? Elencare gli attributi.

X.509 è un certificato a chiave pubblica, ovvero una struttura dati usata per legare in modo sicuro una chiave pubblica ad alcuni attributi; permette di distribuire le chiavi pubbliche per usare le firme digitali in modo sicuro: la chiave pubblica del mittente non è fornita dal mittente, ma è fornita da un'entità esterna fidata attraverso un certificato a chiave pubblica, altrimenti un attaccante potrebbe spacciare la sua chiave pubblica come la chiave pubblica del mittente legittimo.

Un certificato X.509 versione 3 contiene, oltre alla firma digitale della CA, una sequenza di 10 elementi di dato, tra cui:

1. version: è la versione della codifica del certificato (= versione dello standard X.509 −1);

2. serialNumber: è un numero intero assegnato dalla CA, univoco per ogni certificato emesso da una CA data (cioè il nome dell'emettitore e il numero di serie identificano un certificato univoco);

3. signature: contiene l'identificativo di algoritmo dell'algoritmo e della funzione di hash usati dalla CA nella firma del certificato (ad es. sha1WithRSAEncryption);

4. issuer: è il **distinguished name** (DN) che identifica l'entità che ha firmato ed emesso il certificato (ad es. countryName=IT, stateOrProvinceName=Torino, organizationName=Politecnico di Torino, commonName=CA di prova);

5. validity: è l'intervallo di tempo, compreso tra notBefore e notAfter, in cui era valida la chiave privata corrispondente alla chiave pubblica che sta venendo certificata;

6. subject: è il DN che identifica l'entità associata con la chiave pubblica che sta venendo certificata (ad es. commonName=Antonio Lioy);

7. subjectPublicKeyInfo: trasporta il valore in chiaro della chiave pubblica che sta venendo certificata, e identifica l'algoritmo di cui questa chiave pubblica è un'istanza (ad es. rsaEncryption: esponente pubblico e modulo);

10. extensions (facoltativo): contiene eventuali estensioni specifiche del certificato.

89. Algoritmi a chiave simmetrica.

Nella crittografia simmetrica (o crittografia a chiave segreta), la chiave simmetrica è una chiave unica *K*, sia per la criptazione sia per la decriptazione, condivisa solo tra il mittente e il ricevente. La crittografia simmetrica richiede un carico di elaborazione minore rispetto alla crittografia asimmetrica, ed è quindi particolarmente adatta per criptare grosse quantità di dati.

Gli algoritmi simmetrici si suddividono in due classi:

• algoritmi a blocchi (ad es. DES, IDEA, RC2, RC5, AES): suddividono i dati da criptare in blocchi di eguale dimensione, quindi elaborano un blocco alla volta;

• algoritmi di tipo stream (ad es. RC4, SEAL): sono in grado di operare su un flusso di dati, un bit o un byte alla volta.

90. Lei riceve una penna usb contenente un file che deve passare ad un destinatario. Poiché i due peer la ritengono una persona non fidata il mittente calcola anche un digest per proteggere il file contro le modifiche e lo trasmette direttamente al destinatario. È noto che il digest venga calcolato prendendo i 24 bit più significativi dell'hash sha256 del file. Proponga una tecnica per modificare il file senza che i peer se ne accorgano e fornisca anche una stima del numero di operazioni necessarie.

Birthday attack, con un lowerbound di 2^(24/2) = 2^12 hash parto col 50% di probabilità di trovare una hash che fa collisione

91. Descrivere la tecnica della firma digitale ed elencare tutte le funzionalità di sicurezza offerte da essa, identificando quale componente del processo firma/verifica è fondamentale per le singole funzionalità. Spiegare anche il ruolo di un certificato X.509 in questo contesto.

Nella firma digitale viene calcolato un digest con un algoritmo crittografico e associato con un oggetto di dati in modo tale che qualsiasi destinatario dei dati può usare la firma per verificare l'origine e l'integrità dei dati

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il digest md*R* calcolato sui dati ricevuti sarà diverso dal digest md*F* ricevuto e decriptato;

+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

+ non ripudio: il mittente non può negare di aver firmato i dati, a patto che la sua chiave pubblica sia fornita da un certificato a chiave pubblica.

Nel contesto delle firme digitali, un cetificato X.509 serve per determinarne la validità e distribuirne la chiave pubblica associata in maniera autenticata.

92. Come avviene la verifica di un documento firmato?

- Verificare che il certificato sia nel periodo di validità (campi notBefore/notAfter)
- Verificare che il certificato non sia stato revocato (CRL/OCSP)
- Verificare la catena di certificati fino a un trusted root CA
- Verificate la firma decrittandola con la chiave pubblica presente nel certificato e confrontando il risultato con il digest del messaggio (sempre calcolato con l'algoritmo specificato nel certificato

93. Cos'è e a cosa serve PKCS#7?

PKCS #7, evolutosi poi in CMS (Cryptographic Message Syntax), è un formato che permette di creare buste sicure che possono contenere dati di qualsiasi tipo.

94. **Indicare gli errori di questa frase: ho un server che cifra i dati con certificato X.509 a 2048 bit, protetto con un reverse proxy che verifica le password con un algoritmo RIPEMD.**
Il certificato x.509 non è un algoritmo di cifratura ma uno standard per le certificazione dell'autenticità di un utente/host. Mentre RIPEMED è una funzione di hash che può essere utilizzata per verificare una password. Il reverse proxy non protegge ma fa solo forwarding.

    3 errori.

95. **PKCS#12, definizione.**
Si tratta di un formato dati utilizzato per memorizzare in maniera sicura coppie chiavi pubbliche-private. Concetto base è il trasporto di materiale crittografico (personale) tra applicazioni/sistemi diversi. Contiene al suo interno una chiave privata piu uno o piu certificati. Trasporta dunque una chiave privata e uno o piu certificati, e permette il trasporto dell'identità digitale di un utente.

96. **Descrivere il salvataggio di password lato server. Rischi e contromisure.**

97. **Quali sono le principali caratteristiche di una smart-card che la rendono interessante per le applicazioni di ICT?**

    (Risposta del professore)

    Protocollo storage KPR1, on board cryptography.

98. **A vuole mandare a B un file F di 100 MB, avendo le proprietà di sicurezza di riservatezza, autenticazione e integrità. A ha il certificato X.509 di B (la chiave pubblica). Non usare strutture dati complesse e descrivere i passaggi con i nomi dei protocolli piuttosto che con il generico.**
k=DH

    C=AES128_CBC(F,k,IV)

    K=RSA(k, Kpub) (Kpub from certifiate)

    D=HMAC_SHA256(Kpub, C || K || IV)

    send A and B, M=C || K || IV || D

99. **Cosa rappresentano le sigle TSA e TST?**

100. **Per un documento digitally signed: quali sono le possibilità (metodi)? Enveloping signature, enveloped, detached signature. Vantaggi e svantaggi.**
A livello concettuale, la firma digitale può essere allegata al documento in tre formati:

• enveloping signature (ad es. PKCS #7): la firma racchiude il documento, quindi il quest'ultimo va estratto prima di poter essere letto; ha come vantaggio quello di potere cifrare qualsiasi dato, ma come svantaggio c'e il fatto che bisogna modificare le applicazioni

• enveloped signature (ad es. PDF): il documento racchiude la firma, cioè il formato del documento prevede uno spazio per la firma; vantaggio è che la firma è wrappata nel documento, lo svantaggio è che si usa solo per il PDF

• detached signature (ad es. PKCS #7): il documento e la firma sono separati tra loro, e la firma contiene un riferimento (ad es. nome del file) al document; il vantaggio è la sua flessibilità, lo svantaggio è il riusire a mantenere nel tempo l'associazione tra la firma e il documento

101. **Se vogliamo inviare un messaggio PKCS#7 envelopedData a una persona, e a tre persone, cambierà la taglia del messaggio?**
Si, dato che la envelopedData contiene un campo info per ogni ricevente

Capitolo 5
Sicurezza delle reti IP

102. **Descrivere almeno due tipi di attacchi possibili con ICMP e le contromisure da adottare per evitare tali attacchi.**
Smurfing attack: viene mandato un pacchetto ICPM echo request broadcast ad un'intera sottorette fingedosi la vittima; la risposte ricevute dalla sottorette (detta anche reflector) causano una saturazione della scheda di rete della vittima. Per risolverlo bisogna far si di non accettare pacchetti broadcast da rete esterna.
ICMP redirect: un MITM intercetta un pacchetto da host A diretto verso un altro un host e risponde preventivamente con un ICMP redirect verso se stesso
103. **Spiegare l'ICMP redirect attack.**
Un MITM intercetta un pacchetto da host A diretto verso un altro un host e risponde preventivamente con un ICMP redirect verso se stesso

104. **Descrivere l'architettura basic VPN: che cos'è, l'implementazione, vantaggi e svantaggi.**
La basic-VPN e una soluzione piu leggera e permissiva, nella quale IPsec viene installata sui gateway e non sui dispositivi host. Si noti che i gateway

costituiscono dei colli di bottiglia e devono essere potenti al livello computazionale. Tale strategia si basa su un'importante ipotesi, cioe che una parte della rete sia considerata fidata. Fra le zone fidate e quelle non date viene collocato un gateway, punto in cui viene congurato appunto IPsec. Emerge la necessita di utilizzare TUNNEL.

105. Disegnare e discutere della End-to-end security with basic VPN

In una soluzione del genere, IPsec viene installato sia sui nodi host che sui gateway, e si puo utilizzare come doppia linea di difesa. Ad esempio, è possibile attivare AH sugli host e il tunnel mode sui gateway, garantendo una sorta di bilanciamento.

106. Un'azienda decide di collegare due sue filiali con una vpn del fipo basic VPN: dire caratteristiche, vantaggi e rischi

La basic-VPN è una soluzione leggera e permissiva, nella quale IPsec viene installata sui gateway e non sui dispositivi host. Si noti che i gateway costituiscono dei colli di bottiglia e devono essere potenti al livello computazionale. Tale strategia si base su un'importante ipotesi, cioe che una parte della rete sia considerata data. Fra le zone date e quelle non date viene collocato un gateway, punto in cui viene congurato appunto IPsec. Emerge la necessita di utilizzare TUNNEL.

107. Cos'è RADIUS, quali sono le caratteristiche di sicurezza e quale ruolo ha in una architettura di sicurezza.

Radius - Remote Authentication Dial-In User Service - è il piu diffuso protocollo di autenticazione, e supporta autenticazione, autorizzazione e accounting per l'accesso alla rete. L'integrita ed autenticazione dei pacchetti avviene tramite keyed-MD5. La key è shared-secret, mentre client senza key sono ignorati. Ogni pacchetto Radius ha un codice, un numero identicativo, una lunghezza su 16 bit, un autenticatore lungo 128 bit e poi ci sono gli attributi. L'autenticatore autentica la risposta del server ed evita replay. Inoltre, opera un calcolo per mascherare la password. RADIUS fa tendenzialmente da proxy verso altri server di autenticazione: se un utente si presenta al proprio server con un dominio adeguato, il server stesso gestisce l'autenticazione attraverso un DB locale; se viene utilizzato un dominio differente, occorre che il server RADIUS sia in qualche modo federato con il server del dominio cui si vuole fare accesso.

108. Quali sono i problemi di sicurezza del protocollo ICMP?

Il protocollo Internet Control and Management Protocol (ICMP) è vitale per la gestione della rete. Essendo privo di protezione è possibile avere moltissimi tipi di attacchi, in particolare:

• Un attaccante potrebbe sfruttare dei pacchetti destination unreachable (usati da un nodo intermedio per comunicare l'impossibilità di consegnare un pacchetto al destinatario) in modo da bloccare il traffico verso un nodo destinatario causando un

DoS. Questo perché al ricevimento di un pacchetto destination unreachable il nodo mittente interrompe la trasmissione dei pacchetti.

• Tramite un pacchetto source quence (usato per rallentare la trasmissione dei pacchetti quando i buffer di un nodo intermedio sono saturi) un attaccante può andare a diminuire la velocità di trasmissione del mittente, e quindi generare un DoS.

• Possibilità di usare i pacchetti redirect (usati da un nodo intermedio per comunicare ad un altro nodo la strada migliore da seguire per consegnare dei pacchetti) in modo da generare un attacco Man-In-The-Middle logico.

• Uso di un pacchetto time exceeded for a datagram (usato quando si genera un loop nella rete) in modo da generare un DoS e far cadere la connessione tra due nodi.

109. Cos'è un ARP spoofing attack?

Consiste nel modificare l'ARP table della vittima (magari usando strategie di replay o risposta preventiva), per poi impostare attacchi MITM

110. Dire che cos'è dns cache poisoning.

Gli attacchi DNS cache poisoning vengono utilizzati per attirare la vittima a fare una query sul proprio NS, e dunque attirare traco su un certo server.

Ha due versioni:

- La v1 consiste nel fornire una risposta anche a query non effettuate per forzare/sovrascrivere la cache della vittima. La risposta di un NS contiene dunque la traduzione anche di altri siti, che vengono salvati in cache poiché considerati piu "freschi". Si può evitare, ma parzialmente, effettuando un confronto sulla coerenza fra domanda e risposta.
- La v2 consiste nel fare una query e fornire subito, prima che il NS riesca a risolverla, la risposta (falsa) per inserirla nella cache della vittima. La risposta vera, che arriveràa in ritardo, sarà scartata.

111. DNS flash crowd: Spiegazione e contromisure

In un attacco del genere, molti nodi si collegano allo stesso tempo ad un server per metterlo fuori uso. Tale attacco e illegale solo se portato avanti attraverso dei bot. Il DNS ash crowd provoca un sovraccarico di request di un DNS server. Altro problema e costituito dalla traduzione nomi-indirizzi che ora non avviene più mediante sistemista ma in maniera automatica.

112. Ping flooding, cos'è e come difendersi in modo da non alterare il normale traffico tcp/ip

è un attacco di tipo DoS in cui si inviano in modo massivo messaggi ICMP Echo Request senza attenderne la risposta; come per tutti gli attacchi DoS, non esiste alcuna contromisura definitiva, ma solo dei rimedi palliativi basati sull'approccio quantitativo per mitigare gli effetti:

• monitoraggio: si cerca di rilevare eventuali anomalie (ad es. utilizzo delle risorse della CPU e di rete), anche se potrebbero essere originate da semplici malfunzionamenti;

• sovradimensionamento: si progetta il sistema per sopportare più carico di quello richiesto normalmente, così in caso di attacco DoS il sistema resiste per un po' di tempo, lasciando il tempo di identificare la sorgente dell'attacco.

113. Descrivere lo sniffing e almeno due modi di effettuarlo.

Per sniffing s'intende il rilevamento dei pacchetti in transito in una rete e la loro analisi per carpirne informazioni sensibili; al fine di contrastarlo è necessaria cifratura dei pacchetti. Si può effettuare sia in maniera logica, analizzando il traffico in una rete a cui si ha accesso, sia fisica, inserendo un dispositivo (ad es. switch) nei collegamenti della rete

114. Descrivere l'architettura VPN end-to-end: che cos'è, l'implementazione, vantaggi e svantaggi.

Questa architettura prende questo nome perché è quella in cui IPsec viene usato per proteggere il traffico direttamente fra due nodi client-server.

Questo significa che i due nodi su cui è stato installato il software IPsec negoziano tra di loro una SA in modalità transport mode. In altre parole i due nodi si creano un canale virtuale sicuro, con le caratteristiche di sicurezza che hanno negoziato, che rende la protezione del traffico da essi generato indipendente da tutto: non è importante se le LAN non sono sicure, se i gateway sono gestiti da persone non fidate o chi implementa o gestisce le WAN. Se le due macchine sono sicure allora si avrà la protezione completa del traffico di rete, ad eccezione del DoS.

Pro e contro:

\+ I due nodi sono completamente resi indipendenti e protetti da tutto il resto della rete, sia locale che geografica.

− È necessario andare ad installare IPsec su tutti i nodi della rete che si intende andare a proteggere; di conseguenza questa soluzione è usata principalmente quando si hanno pochi nodi da proteggere.

− Il fatto di andare ad installare IPsec sul singolo nodo presuppone che quel nodo abbia le capacità crittografiche necessarie; questo è molto importante per quanto riguarda il client, ma anche per quanto riguarda il server nel caso in cui il numero dei nodi fosse elevato.

− Nel caso che nel canale sia stato implementato riservatezza il gestore della rete locale non può andare a fare monitoraggio del traffico.

115. Che cos'è una S-VPN? Perchè ha questo nome?

Questo tipo di VPN (dove la S sta per Secure) si basa sull'utilizzo di un tunnel, ma i pacchetti prima di essere trasferiti vengono protetti. Questo viene fatto principalmente per proteggersi nei confronti del gestore della rete pubblica. I pacchetti possono essere protetti con:

• Digest, in modo da proteggere integrità e autenticazione. Questo evita che il gestore della rete possa modificare dei pacchetti o addirittura aggiungerne.

• Cifratura per la segretezza, in modo che non sia possibile leggere i pacchetti.

• Numerazione per evitare attacchi di tipo replay.

La cosa importante di questa tecnica è che la protezione deve essere fatta direttamente dal cliente della VPN, e non dal gestore. Se inoltre il cliente decide di utilizzare degli algoritmi crittografici forti, allora l'unico attacco possibile è impedire le comunicazioni mediante DoS.

116. Una azienda deve collegare due sue filiali con una VPN, quale infrastruttura si usa? Come è fatta? Disegnare lo schema, spiegare come viene configurata, vantaggi e svantaggi di questa soluzione.

117. Un'azienda decide di collegare due sue filiali con una VPN del fipo basic-vpn: dire caratteristiche, vantaggi e rischi

Questa architettura implementa l'idea opposta rispetto all'architettura precedente: invece di andare ad implementare IPsec sugli end-node, si presuppone che le reti locali siano fidate e che quelle pericolose siano solamente le reti geografiche. In base a questa idea IPsec viene installata sui gateway, ossia i punti di accesso fra due reti con livello di sicurezza differente: una rete sicura di cui ci si fida (nell'immagine è stata definita come LAN) e una di cui non si si fida (WAN).

Vantaggi e svantaggi:

+ Non occorre più andare a gestire un numero elevato di nodi, ma è sufficiente la gestione del solo gateway.

+ Se il gateway avesse dei problemi computazionali è possibile andare a prendere delle misure andando ad installare degli acceleratori crittografici.

+ La parte di rete fidata non essendo più cifrata può essere soggetta a monitoraggio.

− Non si ha più una protezione end-to-end. Questo significa che se c'è qualche malintenzionato all'interno della rete fidata questo è libero di eseguire qualunque tipo di attacco esso voglia.

118. Una azienda deve collegare due sue filiali con una IPsec del tipo VPN. Disegnare lo schema, spiegare come viene configurata, vantaggi e svantaggi di questa soluzione.

Questo tipo di VPN (detta anche S-VPN, dove la S sta per Secure) si basa sull'utilizzo di un tunnel, ma i pacchetti prima di essere trasferiti vengono protetti. Questo viene fatto principalmente per proteggersi nei confronti del gestore della rete pubblica. I pacchetti possono essere protetti con:

• Digest, in modo da proteggere integrità e autenticazione. Questo evita che il gestore della rete possa modificare dei pacchetti o addirittura aggiungerne.

• Cifratura per la segretezza, in modo che non sia possibile leggere i pacchetti.

• Numerazione per evitare attacchi di tipo replay.

La cosa importante di questa tecnica è che la protezione deve essere fatta direttamente dal cliente della VPN, e non dal gestore. Se inoltre il cliente decide di utilizzare degli algoritmi crittografici forti, allora l'unico attacco possibile è impedire le comunicazioni mediante DoS.

Pro e contro:

+ protegge il client dal gestore, e viceversa

+ l'unico attacco possibile è il DOS

+ prima di metterlo nel tunnel, l'utente può proteggere il pacchetto: digest (integrità e autenticazione), crittografia (riservatezza), numerazione (replay)

- suscettibile a DoS

119. EAP: a cosa serve, differenze rispetto a PAP e CHAP.

Il Extensible Authentication Protocol (EAP) è un protocollo flessibile di autenticazione a livello data-link.

La differenza rispetto a PAP e CHAP (che pure sono protocolli di autenticazione al livello 2) sta nella tecnica usata:

• PAP (Password Authentication Protocol): invia il nome utente e la password in chiaro;

• CHAP (Challenge Handshake Authentication Protocol): usa un sistema di autenticazione a sfida simmetrico, basato sulla password dell'utente;

• EAP (sez. 5.2): fornisce invece tre opzioni di autenticazione: OTP, token based e MD5- challenge(sistema a sfida simile a CHAP e basato su keyed-digest MD5)

120. Radius e quando si usa nelle reti wireless. Problemi di sicurezza in una piccola rete aziendale: che tecnologie adottare?

121. Cos'è IPsec e quali servizi di sicurezza offre.

IPsec è l'architettura proposta dall'IETF per fare sicurezza al livello 3 sia per IPv4 sia per IPv6.

IPsec permette di:

• Creare VPN su reti non fidate.

• Fare sicurezza end-to-end tra due nodi di una rete IP.

Proprietà di sicurezza:

• Autenticazione dei pacchetti IP

• Integrità dei dati trasportati.

• Identificazione del mittente.

• Protezione (parziale) da attacchi di tipo replay.

• Riservatezza dei pacchetti IP tramite cifratura dei dati

122. IPsec in transport mode con ESP: quali misure di sicurezza sono permesse (indicare quelle obbligatorie e quelle facoltative) e come vengono realizzate?

Integrità e autenticazione del pacchetto: keyed-digest
Riservatezza solo del payload: cifratura simmetrica
Protezione parziale replay: sequence number
Integrità+autenticazione (VPN-A) e cifratura(VPN-B) sono opzionali, nel senso che si può avere solo una delle due.

123. SA in transport-mode di tipo IPsec ESP, proprietà di sicurezza, dire quali proprietà di sicurezza sono obbligatorie e quali no (spiegazione)

Integrità e autenticazione del pacchetto: keyed-digest
Riservatezza solo del payload: cifratura simmetrica
Protezione parziale replay: sequence number
Integrità+autenticazione (VPN-A) e cifratura(VPN-B) sono opzionali, nel senso che si può avere solo una delle due.

124. Spiegare attacco smurfing.

viene mandato un pacchetto ICPM echo request broadcast ad un'intera sottorette fingedosi la vittima; la risposte ricevute dalla sottorette (detta anche reflector) causano una saturazione della scheda di rete della vittima. Per risolverlo bisogna far si di non accettare pacchetti broadcast da rete esterna.

125. Spiegare che cos'è 802.1x, identificare chiaramente quali sono i suoi componenti

Lo standard IEEE 802.1x definisce un'architettura generalizzata che fornisce un framework per effettuare:
• **autenticazione a livello MAC** (livello 2): l'accesso alla rete è limitato ai soli utenti abilitati tramite un'autenticazione richiesta dal dispositivo di rete stesso

• **key management**: sono necessarie delle chiavi per proteggere le comunicazioni (indispensabile per wireless)

Dal punto di vista architetturale si distinguono tre entità:

• **supplicant**: è il client dell'utente che "supplica" di avere accesso alla rete;

• **authenticator** (o etherNAS): è il punto di accesso alla rete aziendale o dell'ISP, cioè lo switch o l'access point wireless, che ha lo scopo di:

– bloccare l'accesso alla rete fino a quando il client non è stato autenticato con successo;

– fungere da proxy verso il server durante la fase di autenticazione;

• **server di autenticazione**: è l'AS RADIUS, che ha lo scopo di accettare o rifiutare le richieste di accesso.

126. **ESP: descrivere la procedura, le trasformazioni, come sono ottenute le informazioni richieste.**
Si aggiunge un IV da 64 bit, un payload di cui va fatto il padding, la cui lunghezza viene specificata. Inoltre, viene cifrato anche il tipo di payload. Viene autenticato tutto il pacchetto. Non viene cifrato tutto, bensì solo payload, padding length e payload type.

127. **Descrivere syn cookie e contro quale attacco è.**
Rappresenta l'unico sistema veramente efficace per evitare completamente il SYN flooding. L'idea è quella di usare dei SYN cookie, ossia utilizzare il sequence number del pacchetto SYN-ACK per trasmettere un cookie al client e riconoscere così i client che hanno già inviato il SYN senza memorizzare niente nel server. Tale sequence number sarà calcolato in maniera crittografica, ossia un keyed-digest calcolato sulla data, ora e indirizzo IP del client che ha inviato il SYN.

Capitolo 6
Firewall e IDS/IPS

128. **Un'azienda desidera rendere disponibile ai navigatori internet, un servizio http sulla porta 8080, indicare una configurazione della rete e/o del server per erogare il servizio in modo sicuro e spiegare il perché delle scelte adottate.**
Uso un firewall del tipo screened subnet con il giusto proxy web e web server sulla DMZ così da avere un buon livello di sicurezza dato da gateway, bastion e router con packet filtering, ma allo stesso tempo evitare SPOF dato il doppio controllo fatto sui paccheti

129. **Con riferimento ad un firewall di rete, spiegare brevemente le modalità di configurazione whitelist e blacklist**
Whitelist: tutto ciò che non è esplicitamente concesso, non passa
Blacklist: tutto ciò che non è esplicitamente vietato, non passa

Sono strategie implementate per decidere quale tipo di pacchetti far entrare(o uscire) dalla rete; tendenzialmente si preferisce la prima opzione perché più sicura.

130. **Descrivere l'architettura firewall screened host gateway indicando attori, vantaggi e svantaggi.**
Il ponte tra la rete interna e la rete esterna è spostato sullo screening router, a cui è stata aggiunta una scheda di rete: una volta che un pacchetto proveniente dall'esterno è autorizzato dal packet filter, esso può prendere due strade:

• può essere inviato ancora al gateway (ora diventato un bastion host), se ha bisogno di ulteriore indagine;

• può entrare direttamente nella rete interna, se ha bisogno di essere controllato da un server interno (ad es. server di posta).

Pro e contro:

+ flessibilità: è possibile alleggerire i controlli relativi ad alcuni servizi o host evitando di passare dal gateway.

- mascheramento: il mascheramento è possibile solo per i pacchetti che passano dal bastion host;

- singolo punto di guasto: il firmware del router potrebbe avere dei bug.

131. Descrivere la tecnologia del packet filter e descrivere vantaggi e limitazioni.

Consiste nel filtraggio dei pacchetti in entrata o uscita da un rete, e può essere stateless (static) o statefull (dinamic):
-static: si applica un filtraggio grossolano in base agli indirzzi di livello 3 e le porte di livello 4 con un sistema a blacklist o whitelist
-dinamic: memorizza delle informazioni di stato dal livello trasporto e/o dal livello applicativo; distingue le nuove connessioni da quelle già aperte, grazie a una tabella di stato per le connessioni aperte) i pacchetti che corrispondono ad una riga della tabella sono accettati senza ulteriori controlli.

Pro e contro:
+ molto scalabili
+ buone prestazioni (ma il dinamic leggermente migliore essendo statefull)
+ basso costo
- configurazioni complessa
- poco sicuri (controlli poco precisi)

132. Disegnare lo schema di un'architettura firewall di tipo dual homed gateway, illustrarne il ruolo dei componenti, vantaggi e svantaggi.

Allo screening router è messo in serie un dual-homed gateway, una macchina dotata di due schede di rete, una interfacciata sulla rete esterna e l'altra interfacciata su quella interna, entrambe con instradamento disabilitato, e un processo in esecuzione che ha il compito di decidere quale traffico è autorizzato a passare da un'interfaccia di rete all'altra. Questo sistema ha un doppio punto di controllo:

• il router svolge la funzione di packet filter;

• il dual-homed gateway ospita un circuit-level gateway o un application-level gateway a seconda delle necessità.

Siccome il gateway si interfaccia su due reti diverse, la rete intermedia è isolata dalla rete interna e può essere usata come DMZ per i server pubblici.

Pro e contro:

+ mascheramento: il gateway può mascherare la rete interna;

+ semplicità: l'implementazione è semplice;

+ costo: solo piccoli requisiti hardware aggiuntivi sono richiesti (ad es. scheda di rete veloce);

+ doppia linea di difesa: non basta sfruttare il bug di uno dei due dispositivi per entrare nella rete interna.

- gestione: sono necessari due sistemi;

- collo di bottiglia: tutto il traffico deve passare dal dual-homed gateway;

- flessibilità: alcuni tipi di traffico richiedono il controllo da parte di server nella rete interna (ad es. messaggi di posta elettronica di spam).

133. Packet filter e circuit gateway all'interno di un firewall: somiglianze, differenze, vantaggi e svantaggi di entrambi.

Entrambi compiono filtraggio dei pacchetti in base all'intestazione, ma il packet filter lavora al livello 3, mentre il circuit gateway al livello 4.

Packet filter: consiste nel filtraggio dei pacchetti in entrata o uscita da un rete, e può essere stateless (static) o statefull (dinamic):

-static: si applica un filtraggio grossolano in base agli indirzzi di livello 3 e le porte di livello 4 con un sistema a blacklist o whitelist
-dinamic: memorizza delle informazioni di stato dal livello trasporto e/o dal livello applicativo; distingue le nuove connessioni da quelle già aperte, grazie a una tabella di stato per le connessioni aperte) i pacchetti che corrispondono ad una riga della tabella sono accettati senza ulteriori controlli.

Pro e contro:
+ molto scalabili
+ buone prestazioni (ma il dinamic leggermente migliore essendo statefull)
+ basso costo
- configurazioni complessa
- poco sicuri (controlli poco precisi)

Circuit gateway: è un proxy non "application-aware" che crea un circuito di livello trasporto tra il client e il server senza avere alcuna comprensione della sintassi dei dati in transito

Pro e contro:
+ I server sono isolati da tutti gli attacchi che riguardano:
  - il three-way handshake TCP: la protezione si attiva all'inizio della sessione e dura per tutta la sessione;
  - la frammentazione dei pacchetti IP: il proxy riassembla il pacchetto per comprendere completamente il suo contenuto.

- rottura del modello client-server (per la durata della sessione): può richiedere modifiche alle applicazioni (ad es. autenticazione del client: avviene normalmente a livello applicativo, non a livello trasporto);

- rimangono molte limitazioni proprie del packet filter.

134. Packet filter e application level gateway all'interno di un firewall: somiglianze, differenze, vantaggi e svantaggi di entrambi.

Entrambi compiono filtraggio dei pacchetti in base all'intestazione, ma il packet filter lavora al livello 3, mentre l'application level gateway lavora al livello applicazione.

Packet filter: consiste nel filtraggio dei pacchetti in entrata o uscita da un rete, e può essere stateless (static) o statefull (dinamic):

-static: si applica un filtraggio grossolano in base agli indirzzi di livello 3 e le porte di livello 4 con un sistema a blacklist o whitelist
-dinamic: memorizza delle informazioni di stato dal livello trasporto e/o dal livello applicativo; distingue le nuove connessioni da quelle già aperte, grazie a una tabella di stato per le connessioni aperte) i pacchetti che corrispondono ad una riga della tabella sono accettati senza ulteriori controlli.

Pro e contro:
+ molto scalabili
+ buone prestazioni (ma il dinamic leggermente migliore essendo statefull)
+ basso costo
- configurazioni complessa
- poco sicuri (controlli poco precisi)

Application-level gateway: ispeziona i pacchetti a livello applicativo (payload): è composto al suo interno da una serie di proxy, uno per ogni protocollo applicativo; può svolgere il ruolo di terminatore: interagisce direttamente con il client come se fosse il server, e con il server come se fosse il client; può effettuare il mascheramento o la rinumerazione degli indirizzi IP: può essere necessario se sta agendo da terminatore e uno dei due party chiede l'autenticazione dell'altro; può anche avere funzioni di autenticazione, soprattutto in egress: il gateway chiede al client nella rete esterna di autenticarsi in modo da applicare a esso le politiche appropriate.

Pro e contro:

+ massima sicurezza: le regole sono più granulari e più semplici rispetto al packet filter, in quanto i controlli si basano sul livello applicativo;

+ parallelizzazione: più core della CPU lavorano in parallelo (SMP).

- prestazioni: controlli più approfonditi richiedono più tempo;

- dipendente dalle applicazioni: ogni protocollo applicativo richiede uno specifico proxy:

  – ritardo nel supporto di nuove applicazioni;

  – consumo di risorse: molti proxy significano molti processi;

  – basse prestazioni: i processi lavorano in user mode;

- rottura del modello client-server: può non essere del tutto trasparente ai client, e richiede spesso una modifica dell'applicativo client;

- attacchi: poiché il client interagisce direttamente con il gateway, il sistema operativo del firewall è esposto ad attacchi;

- protocolli di sicurezza di livello applicativo: il firewall potrebbe non essere in grado di interpretare correttamente il contenuto dei pacchetti (ad es. SSL: il contenuto del pacchetto è criptato).

135. Disegnare lo schema dello "Screened Subnet". Indicare il ruolo dei singoli componenti. Vantaggi e svantaggi di questo schema.

Lo screening router è stato diviso in due:

• la parte di packet filter filtra il traffico in ingresso e in uscita;

• la parte di router svolge la funzione di ponte tra le due reti.

Pro e contro:

+ flessibilità: è possibile alleggerire i controlli relativi ad alcuni servizi o host evitando di passare dal gateway;

+ doppia linea di difesa: non basta sfruttare il bug di uno dei due dispositivi per entrare nella rete interna.

- costo: sono necessari tre apparati;

- multi-vendor: gli apparati devono essere di tre produttori diversi, altrimenti potrebbero soffrire di bug comuni.

136. Parlare del firewall; dove si può piazzare in una grossa rete aziendale?

137. Cos'è il circuit gateway e da cosa protegge?

è un proxy non "application-aware" che crea un circuito di livello trasporto tra il client e il server senza avere alcuna comprensione della sintassi dei dati in transito

Pro e contro:

+ I server sono isolati da tutti gli attacchi che riguardano:

• il three-way handshake TCP: la protezione si attiva all'inizio della sessione e dura per tutta la sessione;

• la frammentazione dei pacchetti IP: il proxy riassembla il pacchetto per comprendere completamente il suo contenuto.

- rottura del modello client-server (per la durata della sessione): può richiedere modifiche alle applicazioni (ad es. autenticazione del client: avviene normalmente a livello applicativo, non a livello trasporto);

- rimangono molte limitazioni proprie del packet filter.

138. Classificazioni livelli dei firewall e controlli da fare a ogni livello; differenza packet filter e proxy di circuito.

Il proxy di circuito (reverse proxy) è un filtro ingress posto subito davanti a uno o più server HTTP: fa solo da front-end verso il client, fingendosi il server, e poi passa le richieste al vero server; il packet filter consiste nel filtraggio dei pacchetti in entrata o uscita da un rete al livello 3.

139. Architettura dei firewall (con schema), eventuali miglioramenti.

140. Cos'è IDS?

Intrusion Detection System (IDS) è un sistema per identificare individui che usano un computer o una rete senza autorizzazione

141. Qual è la principale differenza tra un IDS e un IPS?

IDS notifica se rileva un attacco, l'IPS cerca anche di bloccarlo

142. IDS vs IPS: cosa sono e differenze

Intrusion Detection System (IDS) è un sistema per identificare individui che usano un computer o una rete senza autorizzazione.

Intrusion Prevention System (IPS) è un sistema che può rilevare un'attività intrusiva e può anche provare a fermare l'attività, idealmente prima che essa raggiunga i suoi obiettivi.

La differenza è che IDS notifica se rileva un attacco, l'IPS cerca anche di bloccarlo.

143. Illustrare il funzionamento di un componente application-level gateway all'interno di un firewall e discuterne vantaggi e svantaggi.

Ispeziona i pacchetti a livello applicativo (payload): è composto al suo interno da una serie di proxy, uno per ogni protocollo applicativo;

può svolgere il ruolo di terminatore: interagisce direttamente con il client come se fosse il server, e con il server come se fosse il client; può effettuare il mascheramento o la rinumerazione degli indirizzi IP: può essere necessario se sta agendo da terminatore e uno dei due party chiede l'autenticazione dell'altro; può anche avere funzioni di autenticazione, soprattutto in egress: il gateway chiede al client nella rete esterna di autenticarsi in modo da applicare a esso le politiche appropriate.

Pro e contro:

+ massima sicurezza: le regole sono più granulari e più semplici rispetto al packet filter, in quanto i controlli si basano sul livello applicativo;

+ parallelizzazione: più core della CPU lavorano in parallelo (SMP).

- prestazioni: controlli più approfonditi richiedono più tempo;

- dipendente dalle applicazioni: ogni protocollo applicativo richiede uno specifico proxy:

  – ritardo nel supporto di nuove applicazioni;

  – consumo di risorse: molti proxy significano molti processi;

– basse prestazioni: i processi lavorano in user mode;

- rottura del modello client-server: può non essere del tutto trasparente ai client, e richiede spesso una modifica dell'applicativo client;

- attacchi: poiché il client interagisce direttamente con il gateway, il sistema operativo del firewall è esposto ad attacchi;

- protocolli di sicurezza di livello applicativo: il firewall potrebbe non essere in grado di interpretare correttamente il contenuto dei pacchetti (ad es. SSL: il contenuto del pacchetto è criptato).

144. Spiegare in cosa consiste la tecnica IPS.

Intrusion Prevention System (IPS) è un sistema che può rilevare un'attività intrusiva e può anche provare a fermare l'attività, idealmente prima che essa raggiunga i suoi obiettivi.

Un IPS è costituito da:

• IDS: rileva un attacco in corso (ad es. eccesso di pacchetti ICMP);

• firewall dinamico distribuito: reagisce molto velocemente (ad es. blocca tutto il traffico ICMP).

145. Per un'azienda che ha bisogno di avere un web server, un mail server, di fare access control (non tutti possono accedere a Internet), e di ispezionare il contenuto di tutto il traffico, disegnare un'architettura.

Capitolo 7
Sicurezza delle applicazioni di rete

146. **Proprietà di sicurezza di TLS con algoritmi e chiavi.**
A partire da TLS-1.2 abbiamo:
- PEER AUTHN: server obbligatoria, client opzionale. C/R ASYM implicita ed esplicita.
- RISERVATEZZA DATI: opzionali, SYM
- DATA AUTHN/INTEGRITÀ: obbligatorio, keyed-digest negoziata
- FILTERING: obbligatorio, MID implicito
- REPLAY: obbligatorio, MID implicito

Gli algoritmi usati sono HMAC per integrità, e per riservatezza DH + DSA + 3DES

147. **TLS, proprietà di sicurezza obbligatorie e facoltative, dire con quali algoritmi e con quali chiavi vengono realizzate**
A partire da TLS-1.2 abbiamo:
- PEER AUTHN: server obbligatoria, client opzionale. C/R ASYM implicita ed esplicita.
- RISERVATEZZA DATI: opzionali, SYM
- DATA AUTHN/INTEGRITÀ: obbligatorio, keyed-digest negoziata
- FILTERING: obbligatorio, MID implicito
- REPLAY: obbligatorio, MID implicito

Gli algoritmi usati sono HMAC per integrità, e per riservatezza **DH + DSA + 3DES**

148. **Quali sono gli step di trasformazione dei dati quando inviati tramite un canale TLS con la ciphersuite TLS_DHE_DSS_WITH_AES_128_CBC_SHA con ZIP**
1) frammentazione
2) compressione PACK.DATA = zip(PACK.DATA)
3) mac in questo caso un keyed digest utilizzando sha256 immagino quindi PACK.MAC = HMAC-SHA256(key_auth_client_to_server,packet) (considerando il padding se tls oppure senza considerarlo se ssl <= 2.0)
4) padding
5) generazione IV, quindi PACK.IV = rand(128)
6) cifratura utilizzando aes, quindi PACK.DATA = AES-128-CBC(PACK.IV,key_comp_client_to_server,PACK.DATA)
7) invio pacchetto, ovvero send(PACK) # che conterrà IV, DATA e MAC

149. **Descrivere come funziona la client authentication di TLS. Discutere i suoi vantaggi e i suoi svantaggi.**
1)certificate request(client): opzionale, richiesta dal server in fase di handshake
2)certificate(client): Trasporta il certificato per la client authentication. Il certificato deve essere stato emesso da una delle CA date elencate dal server nel messaggio Certicate Request.

3)Cetificate verify: Si tratta di una prova esplicita di firma. Viene verificato effettivamente che si possieda la chiave privata e che si intenda utilizzarla in tale contesto. L'hash è calcolato su tutti i messaggi di handshake che precedono questo ed e firmato con la chiave privata del client (serve per evitare impostori)

150. **TlS client authentication vs HTML form-based authentication: vantaggi, svantaggi e soluzioni**

TLS client auth: Nel caso in cui il canale SSL è stato attivato con client authentication, per autenticarsi l'utente dovrà fornire un certificato X.509, oltre a dover rispondere correttamente alla sfida. In quasto caso il server può effettuare un mapping per far sapere allo sviluppatore applicativo le credenziali dell'utente che ha richiesto accesso ad una determinata risorsa.

Il vantaggio è che l'attaccante potrà andare a sfruttare solamente i bachi contenuti all'interno di TLS; di conseguenza si avrà una superficie d'attacco molto piccola.

Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

HTML form-based: il client invia i propri dati dopo averli inseriti in un form html

Lo svantaggio è che manda le credenziali semplicemente codificate in base64 e non vengono protette da crittografia quindi si può fare sniffing delle credenziali e il server deve anche stare attento a salvarle non in chiaro **mentre come vantaggio è che è veloce e facile da implementare.**

151. **Un'azienda vuole fare TLS client auth su un server web: vantaggi e svantaggi e accorgimenti da applicare su client e server.**
Vantaggi: autenticazione forte, superficie d'attacco ridotta, nessuna password memorizzata sul server, etc...
Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

Accorgimenti: HSM sul server per metterci K privata, smart card o dispositivo sicuro per K privata sul client, HSTS e HPKP (che non c'entrano nulla con la client auth ma a quanto pare andavano detti).

152. **Un progettista web deve scegliere tra realizzare autenticazione degli utenti tramite TLS client authentication oppure HTLM form-based authentication. Illustrare le due soluzioni, con relativi vantaggi e svantaggi e quindi suggerire la soluzione migliore per generici utenti internet**
TLS client auth: Nel caso in cui il canale SSL è stato attivato con client authentication, per autenticarsi l'utente dovrà fornire un certificato X.509, oltre a dover rispondere correttamente alla sfida. In quasto caso il server può effettuare un mapping per far sapere allo sviluppatore applicativo le credenziali dell'utente che ha richiesto accesso ad una determinata risorsa.

Il vantaggio è che l'attaccante potrà andare a sfruttare solamente i bachi contenuti all'interno di TLS; di conseguenza si avrà una superficie d'attacco molto piccola.

Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

HTML form-based: il client invia i propri dati dopo averli inseriti in un form html

Lo svantaggio è che manda le credenziali semplicemente codificate in base64 e non vengono protette da crittografia quindi si può fare sniffing delle credenziali e il server deve anche stare attento a salvarle non in chiaro mentre come vantaggio è che è veloce e facile da implementare.

Data che si parla di utenti generici che potrebbero essere privi di certificato, suggerirei la seconda, ovviamente con i dovuti accorgimenti.

153. Supponiamo di avere un sito web, come si potrebbe fare l'autenticazione dell'utente potendo agire solamente sul nodo di rete che ospita il sito web?

154. Considerando il protocollo TLS-1.0, spiegare quali proprietà di sicurezza offre e per ciascuna di esse indicare se è obbligatoria o opzionale e come viene ottenuta.

• **autenticazione del server** (obbligatoria): all'apertura del canale, il server:

1. si autentica inviando la propria chiave pubblica, tipicamente contenuta dentro un certificato X.509;

2. subisce una sorta di sfida asimmetrica per dimostrare di conoscere la chiave privata corrispondente alla chiave pubblica nel certificato;

• **autenticazione del client** (facoltativa): all'apertura del canale, il client si autentica nello stesso modo del server;

• **autenticazione e integrità dei messaggi** (obbligatorie): tutti i dati trasmessi sono protetti da MAC keyed-digest (ad es. SHA-2) (la firma digitale sarebbe troppo lenta per flussi di dati);

• **riservatezza dei messaggi** (facoltativa): tutti i dati trasmessi sono criptati con una chiave di sessione simmetrica (ad es. 3DES):

– il client decide la chiave;

– il client comunica la chiave al server tramite crittografia a chiave pubblica (ad es. RSA, DH);

• **protezione da attacchi replay e filtering**: ogni messaggio viene numerato con un MID3, garantendo una protezione completa possibile grazie al protocollo di trasporto affidabile (non parziale come in IPsec4):

- replay: i messaggi devono arrivare sempre nello stesso ordine con cui sono stati inviati e non devono essere duplicati;
- filtering (= cancellazione): non devono mancare dei messaggi.

• **protezione dei messaggi**: secondo vari studi il 10% dei messaggi necessita realmente di riservatezza (facoltativa), mentre il 100% necessita di autenticazione e integrità (obbligatorie).

155. Elencare e spiegare le caratteristiche di SSL.

SSL (Secure Socket Layer), proposto inizialmente da Netscape, è un protocollo per creare canali di trasporto sicuri. SSL giace approssimativamente al livello sessione, tra il livello di trasporto e il livello applicativo.

Caratteristiche:

• **autenticazione del server** (obbligatoria): all'apertura del canale, il server:

1. si autentica inviando la propria chiave pubblica, tipicamente contenuta dentro un certificato X.509;

2. subisce una sorta di sfida asimmetrica per dimostrare di conoscere la chiave privata corrispondente alla chiave pubblica nel certificato;

• **autenticazione del client** (facoltativa): all'apertura del canale, il client si autentica nello stesso modo del server;

• **autenticazione e integrità dei messaggi** (obbligatorie): tutti i dati trasmessi sono protetti da MAC keyed-digest (ad es. SHA-2) (la firma digitale sarebbe troppo lenta per flussi di dati);

• **riservatezza dei messaggi** (facoltativa): tutti i dati trasmessi sono criptati con una chiave di sessione simmetrica (ad es. 3DES):

– il client decide la chiave;

– il client comunica la chiave al server tramite crittografia a chiave pubblica (ad es. RSA, DH);

• **protezione da attacchi replay e filtering**: ogni messaggio viene numerato con un MID3, garantendo una protezione completa possibile grazie al protocollo di trasporto affidabile (non parziale come in IPsec4):

- replay: i messaggi devono arrivare sempre nello stesso ordine con cui sono stati inviati e non devono essere duplicati;
- filtering (= cancellazione): non devono mancare dei messaggi.

• **protezione dei messaggi**: secondo vari studi il 10% dei messaggi necessita realmente di riservatezza (facoltativa in SSL3), mentre il 100% necessita di autenticazione e integrità (obbligatorie).

156. Su un server HTTP è necessario autenticare i client, è possibile usare la client authentication di SSL oppure un form con ID e PSW su canale sicuro. Spiegare le due soluzioni, vantaggi e svantaggi di ognuna e dire qual è quella preferibile.

TLS client auth: Nel caso in cui il canale SSL è stato attivato con client authentication, per autenticarsi l'utente dovrà fornire un certificato X.509, oltre a

dover rispondere correttamente alla sfida. In quasto caso il server può effettuare un mapping per far sapere allo sviluppatore applicativo le credenziali dell'utente che ha richiesto accesso ad una determinata risorsa.

Il vantaggio è che l'attaccante potrà andare a sfruttare solamente i bachi contenuti all'interno di TLS; di conseguenza si avrà una superficie d'attacco molto piccola.

Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

HTML form-based: il client invia i propri dati dopo averli inseriti in un form html

Lo svantaggio è che manda le credenziali semplicemente codificate in base64 e non vengono protette da crittografia quindi si può fare sniffing delle credenziali e il server deve anche stare attento a salvarle non in chiaro mentre come vantaggio è che è veloce e facile da implementare.

Sarebbe preferibile la prima al livello di sicurezza.

157. Approcci TLS-then-proto e proto-then-TLS: spiegare il funzionamento, vantaggi e svantaggi dei due approcci.

TLS then proto: ovvero prima viene aperto un canale sicuro e sucessivamente viene utilizzato il protocollo per il trasporto dei dati. La sicurezza non è gestita dal programmatore del server Web, ma è gestita dal sistemista: è compito di quest'ultimo attivare TLS prima di rendere accessibile l'applicazione Web. Questo ha il vantaggio di richiedere un minore lavoro agli sviluppatori, ma allo stesso tempo essi non avranno nessun controllo sui sistemi di sicurezza; occorrerà fidarsi dell'operato dei sistemisti. Occorre quindi avere una sincronizzazione tra il lavoro dei programmatori e quello dei sistemisti.

proto *then TLS:* In questo caso si ha l'apertura iniziale di un normale canale tramite protocollo, e sarà il server a decidere se si vuole fare sicurezza oppure no. Si ha quindi la possibilità di fare upgrading verso TLS di un normale canale. è lo sviluppatore che deve occuparsi della sicurezza: nel momento in cui un utente richiede di accedere a delle risorse protette occorre cessare il normale dialogo traite protocollo, trasformare il canale in sicuro e solo a quel punto potrà riprendere il dialogo. Questo si traduce in un carico di lavoro maggiore per lo sviluppatore in quanto dovrà occuparsi anche della sicurezza, ma ciò può anche essere visto come un vantaggio in quanto è lo sviluppatore stesso che controlla se e quale sicurezza si desidera avere.

Per quanto riguarda i firewall le due soluzioni non sono equivalenti principalmente per il motivo che esse utilizzano porte diverse.

Per quanto riguarda gli IDS, se si utilizza TLS then proto l'IDS sarà solamente in grado di vedere una richiesta di apertura di un canale protetto. Una volta che il canale sarà aperto non sarà più possibile vedere nulla.

Con proto then TLS invece l'IDS può vedere che il canale è stato creato e che per una specifica richiesta il server ha deciso di trasformare il canale in sicuro. L'IDS non sarà comunque in grado di vedere nulla fintanto che TLS sarà attivo, ma almeno si ha un controllo su quali URL viene attivata la sicurezza.

158. **Che cosa sono gli step di trasformazione dei dati quando inviati tramite un canale TLS con la cipher suite DHE-RSA-AES-128-SHA?**
Segmentation, compressione, calcolo del MAC con SHA-1, aggiunto del padding, creazione dell'IV, cifratura con AES, aggiunta dell'header.

159. **Come si può garantire l'autenticazione del traffico HTTP?**

160. **Spiegare Heartbleed**
Heartbleed è un possibile attacco che consiste nel tenere continuamente aperta una connessione senza rinegoziare una sessione SSL. In questo modo un attaccante puo ottenere dati sensibili presenti in un dato blocco di RAM, quali user+pwd e/o chiave privata del server tramite buffer-overflow (se non si usa un HSM, il server tiene la chiave privata in RAM). Si basa sull'estensione Heartbeat che, una volta aperto un canale TLS, continua a scambiare messaggi, anche vuoti, per mantenere la connessione aperta.

161. **Indicare quali proprietà di sicurezza sono disponibili tramite il protocollo TLS-1.2. Per ciascuna proprietà indicare se è opzionale o meno, la metodologia usata per implementarla e le eventuali chiavi specifiche o altri parametri di configurazioni necessari.**

(Risposta dal professore)

- PEER AUTHN: server obbligatoria, client opzionale. C/R ASYM implicita ed esplicita.
- RISERVATEZZA DATI: opzionali, SYM
- DATA AUTHN/INTEGRITÀ: obbligatorio, keyed-digest negoziata
- FILTERING: obbligatorio, MID implicito
- REPLAY: obbligatorio, MID implicito

162. **Si vuole controllare l'accesso alle pagine web ospitate da un server operando solo sulla configurazione del server stesso. Identificare le possibili tecniche utilizzabili, indicandone vantaggi e svantaggi.**

(Risposta del professore)

- INGRESS: semplice, livello S1. svantaggi: IP spoofing, no per-page
- IP-SEC: livello S2. svantaggi: configurare anche il client, no per-page
- TLS c/authn: livello S3, per-page. svantaggi: client certificate che non tutti hanno.
- HTTP basic/digest: semplice, per-page. svantaggi: livello S4, se basic -> TLS (per evitare sniffing)
- FORM based authn: integrità nell'applicazione. svantaggi: livello S5, la forza effettiva dipende dalla tecnica utilizzata.

Capitolo 8
Sicurezza della posta elettronica

163. Quali sono le proprietà di sicurezza di S/MIME clear-signed? Spiegare indicando gli opportuni algoritmi usati e dire se sono obbligatori o opzionali.

Le proprietà offerte sono:

• Non ripudio: tramite f*irma per ricevuta di un documento*, in modo che il destinatario di un messaggio non possa negare di averlo ricevuto.

• *Security label*, meccanismo attraverso il quale si va a classificare ogni messaggio secondo una certa gerarchia di sicurezza. Ad esempio in ambito militare i messaggi vengono classificati in unclassified (leggibili da chiunque), classified (riservati solo a coloro che hanno una certa autorizzazione), secret e top-secret.

• *Mailing-list sicure*, che permette di risolvere il problema di come fare a cifrare i messaggi destinati ad una mailing-list (dove non si ha a disposizione le chiavi pubbliche dei destinatari). Questo però introduce una debolezza perché il messaggio non è più cifrato end-to-end ma il gestore della mailing list potrebbe potenzialmente andare a leggerne il contenuto.

• *Firma degli attributi dei certificati*.

Gli algoritmi usati sono:
• Digest: SHA-1 (obbligatorio) o MD5.

• Firma digitale: DSS (obbligatorio) o digest+RSA (soluzione più usata).

• Scambio chiavi: Diffie Hellman (obbligatorio). In realtà la pratica comune è quella di calcolare una chiave di messaggio cifrandola con la chiave RSA del destinatario.

• Cifratura del messaggio: 3DES o RC2/40 (entrambi obbligatori).

164. Indicare con una formula la struttura di un messaggio S/MIME per un testo T ed una coppia di chiavi (Kpri, Kpub)

165. Dire che cosa ha in più APOP rispetto a POP e come lo implementa
La variante APOP introduce un nuovo comando, chiamato appunto APOP, che sostituisce la coppia di comandi USER + PASS. Questo comando introduce un meccanismo a sfida di tipo simmetrico.

166. Descrivere gli attributi di S/MIME clear-signed indicando quali sono opzionali e descrivere i vari algoritmi di cifratura e le chiavi usate.
• Digest: SHA-1 (obbligatorio) o MD5.

• Firma digitale: DSS (obbligatorio) o digest+RSA (soluzione più usata).

• Scambio chiavi: Diffie Hellman (obbligatorio). In realtà la pratica comune è quella di calcolare una chiave di messaggio cifrandola con la chiave RSA del destinatario.

• Cifratura del messaggio: 3DES o RC2/40 (entrambi obbligatori).

167. Con riferimento ad un sistema di gestione della posta elettronica Internet (MHS, Mail Handling System) identificare i possibili problemi di sicurezza ed indicare quali tecniche di protezione si possono applicare per risolvere o mitigare ciascun problema.
Sicurizzare la posta elettronica non è banale:

• Sistema connectionless, ossia non si ha un collegamento diretto tra il mittente e il destinatario. Anzi si parla di sistema *store-and-forward*, ossia il messaggio prima di essere inviato da un nodo all'altro viene prima salvato in locale e solo in un secondo momento viene inoltrato.

• Uso di MTA non fidati su cui si va a memorizzare (anche se temporaneamente) i messaggi.

• Livello di sicurezza del MS sul quale si va a memorizzare i messaggi prima che essi vengano letti.

• Si potrebbe implementare un sistema di cifratura, ma si avrebbero dei problemi nel caso in cui si usasse una mailing-list (problema di implementare la cifratura per tutti gli appartenenti della mailing-list).

• Poiché la posta elettronica è ormai un sistema di largo utilizzo, apportare delle modifiche non è una cosa così semplice da fare.

168. S/MIME: indicare gli algoritmi di cifratura, hashing e firma, sia obbligatori che opzionali, ed indicare come ciascuno di essi viene utilizzato all'interno di S/MIME.

• Digest: SHA-1 (obbligatorio) o MD5.

• Firma digitale: DSS (obbligatorio) o digest+RSA (soluzione più usata).

• Scambio chiavi: Diffie Hellman (obbligatorio). In realtà la pratica comune è quella di calcolare una chiave di messaggio cifrandola con la chiave RSA del destinatario.

• Cifratura del messaggio: 3DES o RC2/40 (entrambi obbligatori).

169. Dove è meglio fare l'autenticazione del mittente in un sistema di posta tra MTA e MSA?

Authn al MSA nei confronti dei suoi utenti

170. Funzionamento del PGP e perché alla gente non piace.

PGP è un sistema per fare autenticazione, integrità e riservatezza di dati generici. Le chiavi sono conservate personalmente da ogni utente nel cosiddetto key-ring. Esse sono distribuite direttamente dai proprietari, ad esempio all'interno dei famosi PGP party, oppure andando a caricarle all'interno di un key-server.

PGP è stato integrato in molti sistemi di posta elettronica, e si è anche avuto qualche tentativo di introduzione nel mercato aziendale. Ma alle aziende non piace molto l'idea dei PGP party.

171. PGP, dire caratteristiche, vantaggi e svantaggi

PGP è un sistema per fare autenticazione, integrità e riservatezza di dati generici: non usa certificati X.509, ma usa uno schema di certificazione delle chiavi molto peculiare in cui si parla di amici (fidati e non fidati), e di usare un algebra di propagazione della fiducia; le chiavi sono conservate personalmente da ogni utente nel cosiddetto key-ring. Esse sono distribuite direttamente dai proprietari, ad esempio

all'interno dei famosi PGP party, oppure andando a caricarle all'interno di un key-server.

Lo svantaggio principale sta nel sistema di distribuzione delle chiavi, non ritenuto abbastanza sicuro.

172. S/MIME: breve descrizione.

S/MIME è il principale standard oggi usato per la sicurezza dei messaggi MIME, e offre funzionalità di firma digitale e di cifratura tramite l'utilizzo di certificati X.509v3.

173. Con riferimento all'anti-spam per le MTA in ingresso, descrivere nolisting, greylisting, basato su DNS, i loro vantaggi e svantaggi.

DNSBL (DNS blacklists and whitelists): il suo funzionamento è il seguente: si riceve una richiesta di collegamento da parte di un MTA esterno, avente indirizzo A.B.C.D, e si verifica se questo indirizzo è noto per spedire spam eseguendo un'operazione di lookup DNS; lo svantaggio è che una volta entrati in una lista, è difficile uscirne

Greylisting un mail server che utilizza questa tecnica rifiuterà temporaneamente tutte le e-mail da un mittente che non conosce. Se l'e-mail è legittima, il mail server del mittente ritenterà l'invio, e questa volta l'operazione verrà accettata. Se l'e-mail viene inviata da uno spammer, probabilmente non si avrà un ulteriore tentativo poiché il mail server dello spammer avendo a disposizione migliaia (o milioni) di indirizzi email, passerebbe oltre non occupandosi degli errori. Questa tecnica ha il grosso svantaggio di ritardare non soltanto le mail di spam, ma anche qualunque messaggio di posta elettronica si riceva.

Nolisting: è sempre basata sulla teoria che gli spammer non hanno tempo da perdere, e quindi non vanno a provare tutti gli MX (Mail eXchanger, ossia un'incoming MTA nella terminologia dei DNS) definiti per ciascun dominio. In particolare i domini che utilizzano questa tecnica vanno a definire tre diversi MX:

• 1 MX: non risponde mai.

• 2 MX: funziona regolarmente.

• 3 MX: non risponde mai.

Questo viene fatto perché solitamente gli spammer utilizzano il primo o il terzo MX, non li provano tutti. Questa tecnica ha il vantaggio di bloccare, o comunque ritardare, gli spammer ma causa anche un ritardo delle mail. Si ha però il vantaggio di non sovraccaricare ulteriormente l'MTA perché si andrà a ricevere solamente la posta valida.

174. Spiegare tre tecniche anti-spam per incoming MTA, identificandone per ognuna vantaggi e svantaggi (come precedente)

DNSBL (DNS blacklists and whitelists): il suo funzionamento è il seguente: si riceve una richiesta di collegamento da parte di un MTA esterno, avente indirizzo

A.B.C.D, e si verifica se questo indirizzo è noto per spedire spam eseguendo un'operazione di lookup DNS; lo svantaggio è che una volta entrati in una lista, è difficile uscirne

Greylisting un mail server che utilizza questa tecnica rifiuterà temporaneamente tutte le e-mail da un mittente che non conosce. Se l'e-mail è legittima, il mail server del mittente ritenterà l'invio, e questa volta l'operazione verrà accettata. Se l'e-mail viene inviata da uno spammer, probabilmente non si avrà un ulteriore tentativo poiché il mail server dello spammer avendo a disposizione migliaia (o milioni) di indirizzi email, passerebbe oltre non occupandosi degli errori. Questa tecnica ha il grosso svantaggio di ritardare non soltanto le mail di spam, ma anche qualunque messaggio di posta elettronica si riceva.

Nolisting: è sempre basata sulla teoria che gli spammer non hanno tempo da perdere, e quindi non vanno a provare tutti gli MX (Mail eXchanger, ossia un'incoming MTA nella terminologia dei DNS) definiti per ciascun dominio. In particolare i domini che utilizzano questa tecnica vanno a definire tre diversi MX:

• 1 MX: non risponde mai.

• 2 MX: funziona regolarmente.

• 3 MX: non risponde mai.

Questo viene fatto perché solitamente gli spammer utilizzano il primo o il terzo MX, non li provano tutti. Questa tecnica ha il vantaggio di bloccare, o comunque ritardare, gli spammer ma causa anche un ritardo delle mail. Si ha però il vantaggio di non sovraccaricare ulteriormente l'MTA perché si andrà a ricevere solamente la posta valida.

175. Comando AUTH di ESMTP

176. Autenticare il mittente di posta elettronica: MS, MSA o MTA?
MSA

177. Con riferimento ai formati per la creazione di un documento elettronico con firma digitale, descrivere le soluzioni disponibili e discuterne i relativi vantaggi e svantaggi.

(Risposta del professore)

- Enveloping signature (PKCS #7)

vantaggi: applicabile su tutti gli oggetti
svantaggi: bisogna modificare le applicazioni

- Enveloped signature (PDF)

vantaggi: wrapping/wrapper

svantaggi: utilizzabile solo per quell’applicazione

- Detached signature (PKCS #7)

vantaggi: applicabile su tutti gli oggetti
svantaggi: link tra firma e documento

Capitolo X
Domande non ancora catalogate

178. Un consulente propone di basare l'auth sul login invece di usare HTML, discutere